

Guía del estudiante

Módulo 2:

Authentication and access

Implement authentication and access management. 25 a 30% del examen.

Modelo invertido: **esta guía se estudia antes de la sesión**. En vivo cazamos trampas y jugamos Kahoot con el porqué de cada distractor.

Sin dumps

Todo el contenido es original y está anclado a Microsoft Learn con links directos a los párrafos. Skills outline vigente: 27 de abril de 2026.

Contiene: mapa de skills con deep links · 12 trampas con frase clave · 3 visuales · 44 preguntas estilo examen con explicación por distractor · plan de la semana y ritual post-examen.

0. Cómo usar esta guía (20 minutos de lectura, 90 de práctica)

1. Lee el mapa

Sección 1. Un punto clave por skill del outline. Si algo no te suena, abre el deep link: cae justo en el párrafo que el examen pregunta.

2. Aprende las 12 trampas

Sección 2. Cada una trae la frase que la resume, la regla, y las palabras de la pregunta que la delatan.

3. Contesta el banco sin ver respuestas

Sección 4. Anota tus respuestas. Luego revisa la sección 5 y lee el "por qué las otras no": ahí está el valor.

Las preguntas que resuelven casi todo M2: Método, política, riesgo y tráfico. Cuando no sepas la respuesta, pregúntate:

1. **Método:** ¿qué tan fuerte es? MFA, passwordless o phishing-resistant, y dónde se configura cada uno.
2. **Política:** ¿qué decide? Si nadie dice que no, el token sale. El block, el break-glass y el context se diseñan a propósito.
3. **Riesgo:** ¿cuál es y cómo se cura? User risk con password o risk remediation, sign-in risk con MFA, workload identities con otra licencia.
4. **Tráfico:** ¿por dónde pasa? Microsoft, Private o Internet profile, y qué agrega cada uno.

Con eso eliminas dos distractores en la mayoría de las preguntas del módulo.

Datos duros del examen. 700 de 1000 para pasar (escala ajustada, no 70% de aciertos). Practice assessment oficial gratis: learn.microsoft.com/credentials/certifications/exams/sc-300/practice/assessment. Exam sandbox: aka.ms/examdemo. Study guide oficial: learn.microsoft.com/credentials/certifications/resources/study-guides/sc-300.

1. Mapa del módulo: skills, punto clave y deep links

Cada fila corresponde a un bullet del skills outline oficial. El punto clave es lo que el examen realmente mide; los deep links caen en el párrafo exacto de Learn.

Subdominio 1: Plan, implement, and manage Microsoft Entra user authentication

Módulos oficiales en Learn: [secure-aad-users-with-mfa](#) · [manage-user-authentication](#)

Skill Plan for authentication

Elegir métodos por fuerza: phishing-resistant (WHfB, platform credential de macOS, passkeys, CBA) por encima de push, OTP y SMS. Habilitar más de un método por usuario y proteger el registro con CA y TAP.

Link principal: [entra/identity/authentication/howto-mfa-getstarted](#)

- [concept-authentication-methods](#) #phishing-resistant-authentication-methods
- [howto-mfa-getstarted](#) #choose-authentication-methods-for-mfa
- [howto-mfa-getstarted](#) #plan-user-registration

Skill Implement and manage authentication methods: certificate-based authentication

La CA se sube al PKI-based trust store (Privileged Authentication Administrator) con CRL por HTTP; sin CRL no hay revocación. En authentication binding el default es single-factor y la regla de policy OID gana a la de issuer. Required affinity High quita los bindings low (PrincipalName, RFC822Name, Subject, IssuerAndSubject).

Link principal: [entra/identity/authentication/how-to-certificate-based-authentication](#)

- [how-to-certificate-based-authentication](#) #step-1-configure-the-cas-with-a-pki-based-trust-store
- [how-to-certificate-based-authentication](#) #test-custom-authentication-binding-rules
- [concept-certificate-based-authentication-technical-deep-dive](#) #username-binding-policy

Skill Implement and manage authentication methods: Temporary Access Pass

Se habilita en la Authentication methods policy (Authentication Policy Administrator). Vida de 10 minutos a 30 días (default 1 hora), largo de 8 a 48, una TAP por usuario. One-time: registrar en 10 minutos. Authentication Admin crea TAP a members; Privileged Authentication Admin también a admins.

Link principal: [entra/identity/authentication/howto-authentication-temporary-access-pass](#)

- [howto-authentication-temporary-access-pass](#) #enable-the-temporary-access-pass-policy
- [howto-authentication-temporary-access-pass](#) #create-a-temporary-access-pass
- [howto-authentication-temporary-access-pass](#) #limitations

Skill Implement and manage authentication methods: OAuth 2.0 tokens (y OATH tokens)

Access token de 60 a 90 minutos (con CAE hasta 28 horas), refresh token de 90 días (24 horas en SPA). Refresh y session token lifetime ya no se configuran desde el 30 de enero de 2021: se usa sign-in frequency. OATH: TOTP de 30 o 60 segundos, hasta 5 tokens o apps por usuario, HOTP no soportado.

Link principal: [entra/identity-platform/refresh-tokens](#)

- [configurable-token-lifetimes](#) #token-lifetime-policies-for-refresh-tokens-and-session-tokens-retired
- [refresh-tokens](#) #token-revocation
- [concept-authentication-oath-tokens](#) #hardware-oath-tokens-preview

Skill Implement and manage authentication methods: Microsoft Authenticator

Tres usos distintos: push MFA con number matching, passwordless phone sign-in (no es phishing-resistant) y passkey device-bound (sí es phishing-resistant). Additional context (app y ubicación) se activa en Configure. Los passkeys de Authenticator se permiten por AAGUID en la política Passkey (FIDO2).

Link principal: [entra/identity/authentication/concept-authentication-authenticator-app](#)

- [concept-authentication-authenticator-app](#) #passkey-sign-in
- [how-to-enable-authenticator-passkey](#) #configure-a-profile-for-passkeys-in-authenticator
- [how-to-mfa-additional-context](#) #enable-additional-context-in-the-microsoft-entra-admin-center

Skill Implement and manage authentication methods: passkeys (FIDO2)

Passkey profiles por grupo: tipo (device-bound o synced), enforce attestation y key restrictions por AAGUID (allow o block). Synced passkeys no soportan attestation. MFA en los últimos 5 minutos para registrar. Sin licencia extra y sin soporte para guests.

Link principal: [entra/identity/authentication/how-to-authentication-passkeys-fido2](#)

- [how-to-authentication-passkeys-fido2](#) #passkey-profiles
- [how-to-authentication-passkeys-fido2](#) #synced-passkeys-fido2
- [how-to-authentication-passkeys-fido2](#) #enforce-passkey-fido2-sign-in

Skill Implement and manage tenant-wide multifactor authentication (MFA) settings

Report suspicious activity pone al usuario en High user risk. Trusted IPs (P1, solo IPs públicas en MFA de nube, hasta 50 rangos) contra named locations de CA. Remember MFA choca con sign-in frequency. Migración legacy: Pre-migration, Migration in Progress, Migration Complete.

Link principal: [entra/identity/authentication/howto-mfa-mfasettings](#)

- [howto-mfa-mfasettings](#) #report-suspicious-activity
- [howto-mfa-mfasettings](#) #trusted-ips
- [concept-authentication-methods-manage](#) #migration-between-policies

Skill Configure and deploy self-service password reset (SSPR)

En el portal, Selected acepta un solo grupo (nested sí cuenta). Se piden 1 o 2 métodos. Admins: política two-gate fija, sin security questions. Writeback con Connect Sync o Cloud Sync, requiere P1 y se activa en Connect y en On-premises integration. No se garantiza con staged rollout.

Link principal: [entra/identity/authentication/concept-sspr-howitworks](#)

- [tutorial-enable-sspr](#) #enable-self-service-password-reset
- [concept-sspr-policy](#) #administrator-reset-policy-differences
- [tutorial-enable-sspr-writeback](#) #enable-password-writeback-for-sspr

Skill Implement and manage Windows Hello for Business

Cloud Kerberos trust es el modelo recomendado y el único híbrido sin PKI. Pasos: crear el objeto Microsoft Entra Kerberos (Set-AzureADKerberosServer), activar "Use Windows Hello for Business" y "Use cloud trust for on-premises authentication", enrolar. Si "Use certificate for on-premises authentication" está activo, gana certificate trust.

Link principal: [windows/security/identity-protection/hello-for-business/deploy/hybrid-cloud-kerberos-trust](#)

- [hybrid-cloud-kerberos-trust](#) #deploy-microsoft-entra-kerberos
- [hybrid-cloud-kerberos-trust](#) #configure-windows-hello-for-business-policy-settings
- [#pki-requirements](#)

Skill Disable accounts and revoke user sessions

Híbrido: deshabilitar en AD, resetear el password dos veces, luego Revoke-MgUserSignInSession (o Revoke sessions) y deshabilitar los devices. Los access tokens siguen vivos hasta expirar, salvo en apps con CAE.

Link principal: [entra/identity/users/users-revoke-access](#)

- [users-revoke-access](#) #revoke-access-for-a-user-in-the-hybrid-environment
- [users-revoke-access](#) #microsoft-entra-environment
- [users-revoke-access](#) #when-access-is-revoked

Skill Implement and manage Microsoft Entra password protection

Global list siempre activa. Custom list de hasta 1000 términos de 4 a 16 caracteres (P1). On-prem: proxy en un server del dominio, DC agent en cada DC (con reboot), los DCs nunca salen a internet. Audit registra y acepta; Enforced rechaza.

Link principal: [entra/identity/authentication/concept-password-ban-bad](#)

- [tutorial-configure-custom-password-protection](#) #configure-custom-banned-passwords
- [concept-password-ban-bad-on-premises](#) #design-principles
- [howto-password-ban-bad-on-premises-operations](#) #modes-of-operation

Skill Enable Microsoft Entra Kerberos authentication for hybrid identities

Entra ID actúa como KDC en la nube: Cloud TGT para KERBEROS.MICROSOFTONLINE.COM y partial TGT que se canjea en AD. En Azure Files: habilitar en el storage account, admin consent a la app generada y clientes con CloudKerberosTicketRetrievalEnabled. Un solo identity source por storage account y no soporta MFA (excluir la app de CA).

Link principal: [entra/identity/authentication/kerberos](#)

- [kerberos](#) #mfa-incompatibility-for-azure-files-authentication
- [storage-files-identity-auth-hybrid-identities-enable](#) #configure-the-clients-to-retrieve-kerberos-tickets
- [howto-authentication-passwordless-security-key-on-premises](#) #create-a-kerberos-server-object

Subdominio 2: Plan, implement, and manage Microsoft Entra Conditional Access

Módulos oficiales en Learn: [plan-implement-administer-conditional-access](#)

Skill Plan Conditional Access policies

Mínimo P1 (P2 para usar riesgo). Security defaults y CA no se combinan. Si ninguna política dispara un control, el token se emite: para "solo Finance entra" hace falta una política de block aparte. Excluir break-glass. Límite de 240 políticas. Security Reader lee, CA Administrator crea.

Link principal: [entra/identity/conditional-access/plan-conditional-access](#)

- [plan-conditional-access](#) #combining-policies
- [plan-conditional-access](#) #user-exclusions
- [security-defaults](#) #disabling-security-defaults

Skill Implement Conditional Access policy assignments

Users: All, guests por tipo y por tenant, directory roles (solo built-in, no AU-scoped ni custom), grupos con nested. Workload identities: solo single-tenant. Target resources: apps, user actions, authentication context y perfiles de GSA. Excluye le gana a include.

Link principal: [entra/identity/conditional-access/concept-conditional-access-users-groups](#)

- [concept-conditional-access-users-groups](#) #include-users
- [concept-conditional-access-users-groups](#) #exclude-users
- [concept-conditional-access-cloud-apps](#) #user-actions

Skill Implement Conditional Access policy controls

Block o grant con MFA, authentication strength, compliant, hybrid joined, app protection, password change, risk remediation, ToU. Por default es AND. No se mezclan Require MFA y Require authentication strength. Tres strengths built-in que no se editan.

Link principal: [entra/identity/conditional-access/concept-conditional-access-grant](#)

- [concept-conditional-access-grant](#) #grant-access
- [concept-authentication-strengths](#) #built-in-authentication-strengths
- [concept-authentication-strengths](#) #limitations

Skill Test and troubleshoot Conditional Access policies

Report-only evalúa sin aplicar y no sirve para User Actions. What If simula por identidad, solo evalúa políticas On o report-only y no incluye service dependencies. En sign-in logs: pestañas Conditional Access y Report-only.

Link principal: [entra/identity/conditional-access/what-if-tool](#)

- [what-if-tool](#) #how-it-works
- [concept-conditional-access-report-only](#) #policy-evaluation-results
- [plan-conditional-access](#) #troubleshoot-conditional-access-policies

Skill Implement session management

Sign-in frequency (horas, días o Every time) reemplaza a los token lifetimes retirados. Persistent browser session exige All resources y le gana al "Stay signed in?" de branding. No mezclar con Remember MFA. CAE se desactiva solo desde session con All resources y sin condiciones.

Link principal: [entra/identity/conditional-access/concept-session-lifetime](#)

- [concept-session-lifetime](#) #user-sign-in-frequency
- [howto-conditional-access-session-lifetime](#) #policy-2-persistent-browser-session
- [concept-conditional-access-session](#) #customize-continuous-access-evaluation

Skill Implement device-enforced restrictions

Grant compliant o hybrid joined, filter for devices (con operadores negativos alcanza a devices no registrados; extensionAttributes piden device Intune, compliant o hybrid) y app enforced restrictions (SharePoint y Exchange limitados en devices no administrados).

Link principal: [entra/identity/conditional-access/concept-condition-filters-for-devices](#)

- [concept-condition-filters-for-devices](#) #policy-behavior-with-filter-for-devices
- [concept-conditional-access-session](#) #application-enforced-restrictions
- [concept-conditional-access-grant](#) #require-device-to-be-marked-as-compliant

Skill Implement continuous access evaluation

Eventos críticos: usuario deshabilitado o borrado, password cambiado o reseteado, MFA habilitado, revoke de refresh tokens y high user risk. Hasta 15 minutos de latencia; tokens de hasta 28 horas. Solo IP named locations. Guests no. Cambios de grupo o de política pueden tardar hasta un día.

Link principal: [entra/identity/conditional-access/concept-continuous-access-evaluation](#)

- [concept-continuous-access-evaluation](#) #critical-event-evaluation
- [concept-continuous-access-evaluation](#) #supported-location-policies
- [concept-continuous-access-evaluation](#) #group-membership-and-policy-update-effective-time

Skill Configure authentication context

Etiquetas c1 a c99 con "Publish to apps"; la política las elige en Target resources. Las consumen SharePoint (sensitivity label o Set-SPOSite), Defender for Cloud Apps, apps propias, PIM y protected actions. En PIM no se combina con un directory role en la misma política.

Link principal: [entra/identity/conditional-access/concept-conditional-access-cloud-apps#authentication-context](#)

- [concept-conditional-access-cloud-apps](#) #configure-authentication-contexts
- [authentication-context-example](#) #set-up-an-authentication-context
- [pim-how-to-change-default-settings](#) #on-activation-require-microsoft-entra-conditional-access-authentication-context

Skill Implement protected actions

CA sobre permisos (CA policies, named locations, cross-tenant access settings, hard delete) sin importar el rol. Pasos: authentication context con política en On, Roles & admins > Protected actions, probar. Lo hace CA Admin o Security Admin, pide P1. Azure PowerShell falla; Microsoft Graph PowerShell sí hace step-up.

Link principal: [entra/identity/role-based-access-control/protected-actions-overview](https://entra.microsoft.com/entra/identity/role-based-access-control/protected-actions-overview)

- [protected-actions-overview](#) #what-permissions-can-be-used-with-protected-actions
- [protected-actions-add](#) #step-2-add-protected-actions
- [protected-actions-add](#) #symptom---policy-is-never-satisfied

Skill Create a Conditional Access policy from a template

Categorías: Secure foundation, Zero Trust, Remote work, Protect administrator, Emerging threats, AI Agents. La política nace en report-only y solo excluye al usuario que la crea. Se puede editar y exportar o importar JSON.

Link principal: [entra/identity/conditional-access/concept-conditional-access-policy-common](https://entra.microsoft.com/entra/identity/conditional-access/concept-conditional-access-policy-common)

- [concept-conditional-access-policy-common](#) #template-categories
- [concept-conditional-access-policy-common](#) #user-exclusions
- [plan-conditional-access](#) #deploy-conditional-access-policies

Subdominio 3: Manage risk by using Microsoft Entra ID Protection

Módulos oficiales en Learn: [manage-azure-active-directory-identity-protection](#)

Skill Implement and manage user risk by using Microsoft Entra ID Protection or Conditional Access policies

User risk High: Require risk remediation (con password: secure password change; passwordless: revoca sesiones y pide sign-in) o Require password change. Se agregan solos auth strength y SIF Every time. Pide P2. La política legacy se retira el 1 de octubre de 2026.

Link principal: [entra/id-protection/concept-identity-protection-policies](https://entra.microsoft.com/entra/id-protection/concept-identity-protection-policies)

- [concept-identity-protection-policies](#) #user-risk-based-conditional-access-policy
- [concept-identity-protection-policies](#) #require-risk-remediation-control
- [howto-identity-protection-configure-risk-policies](#) #migrate-risk-policies-to-conditional-access

Skill Implement and manage sign-in risk by using Microsoft Entra ID Protection or Conditional Access policies

Sign-in risk Medium y High: auth strength MFA y SIF Every time. Completar MFA remedia el riesgo. Un usuario sin MFA registrado queda bloqueado. No combinar user risk y sign-in risk en la misma política.

Link principal: [entra/id-protection/howto-identity-protection-configure-risk-policies](https://entra.microsoft.com/entra/id-protection/howto-identity-protection-configure-risk-policies)

- [howto-identity-protection-configure-risk-policies](#) #sign-in-risk-policy-in-conditional-access
- [howto-identity-protection-configure-risk-policies](#) #microsoft-recommendations
- [howto-identity-protection-remediate-unblock](#) #self-remediation-of-sign-in-risk

Skill Implement and manage multifactor authentication registration by using authentication methods and registration campaigns

MFA registration policy de ID Protection: 14 días para registrar (Security Administrator, P2). Registration campaign: Authenticator o passkey, uno a la vez; Authenticator en modo Any o Push; snooze de 0 a 14 días; 3 snoozes si Limited está activo.

Link principal: [entra/identity/authentication/how-to-mfa-registration-campaign](#)

- [how-to-mfa-registration-campaign](#) #prerequisites
- [how-to-mfa-registration-campaign](#) #snooze-experience
- [howto-identity-protection-configure-mfa-policy](#) #user-experience

Skill Monitor, investigate and remediate risky users and risky sign-ins

Reportes Risky users, Risky sign-ins y Risk detections. Roles: Global Reader ve, Security Operator descarta riesgo, User Administrator resetea. Confirm compromised, confirm safe o dismiss. Con PHS, el cambio de password on-prem puede resetear el user risk.

Link principal: [entra/id-protection/howto-identity-protection-remediate-unblock](#)

- [howto-identity-protection-remediate-unblock](#) #prerequisites
- [howto-identity-protection-investigate-risk](#) #investigation-and-risk-remediation-framework
- [howto-identity-protection-remediate-unblock](#) #allow-on-premises-password-reset-to-remediate-user-risks

Skill Monitor, investigate, and remediate risky workload identities

Las detecciones llegan sin licencia pero con poco detalle. El CA basado en riesgo pide Workload Identities Premium y solo cubre service principals single-tenant (no managed identities ni SaaS multitenant). Remediar: inventario, credencial nueva (certificado), quitar las viejas y rotar secretos de Key Vault.

Link principal: [entra/id-protection/concept-workload-identity-risk](#)

- [concept-workload-identity-risk](#) #prerequisites
- [concept-workload-identity-risk](#) #enforce-access-controls-with-risk-based-conditional-access
- [concept-workload-identity-risk](#) #remediate-risky-workload-identities

Subdominio 4: Implement Global Secure Access

Módulos oficiales en Learn: [deploy-configure-microsoft-entra-global-secure-access](#)

Skill Deploy Global Secure Access clients

Clientes para Windows, macOS, Android e iOS. En Windows: device joined, hybrid joined o registered (registered solo lleva Private Access), Windows 10 LTSC 2021 o posterior de 64 bits o Windows 11, sin AVD multi-session, admin local para instalar, /quiet o Intune. Deshabilitar QUIC y DNS over HTTPS.

Link principal: [entra/global-secure-access/how-to-install-windows-client](#)

- [how-to-install-windows-client](#) #prerequisites
- [how-to-install-windows-client](#) #automated-installation
- [how-to-install-windows-client](#) #restrict-nonprivileged-users

Skill Deploy and manage Private Access

Reemplaza la VPN. Quick Access es el bloque principal de FQDN e IPs; una Global Secure Access app (per-app access) da CA distinto a un subconjunto. Pasos: connector group con conector activo, Quick Access con app segments, asignar usuarios (sin nested groups), CA y habilitar el Private access profile.

Link principal: [entra/global-secure-access/concept-private-access](#)

- [how-to-configure-quick-access](#) #high-level-steps
- [how-to-configure-quick-access](#) #assign-users-and-groups
- [concept-private-access](#) #global-secure-access-app

Skill Deploy and manage Internet Access

Secure Web Gateway con web content filtering por categoría, URL o FQDN. Flujo: Internet access profile, filtering policy, security profile y CA con "All internet resources with Global Secure Access" y la sesión "Use Global Secure Access security profile". El baseline profile cubre remote networks sin CA.

Link principal: [entra/global-secure-access/how-to-configure-web-content-filtering](#)

- [how-to-configure-web-content-filtering](#) #high-level-steps
- [how-to-configure-web-content-filtering](#) #create-a-security-profile
- [how-to-configure-web-content-filtering](#) #enable-web-content-filtering-for-remote-network-traffic

Skill Deploy and manage Internet Access for Microsoft 365

Microsoft traffic profile (Exchange, SharePoint y OneDrive, Teams, Microsoft 365 Common) incluido en P1. Habilita compliant network check, universal tenant restrictions (TRv2) y source IP restoration. Lo que marcas Bypass en el Microsoft profile no lo toma el Internet access profile.

Link principal: [entra/global-secure-access/how-to-manage-microsoft-profile](#)

- [how-to-manage-microsoft-profile](#) #microsoft-traffic-policies
- [how-to-compliant-network](#) #protect-your-resources-behind-the-compliant-network
- [how-to-universal-tenant-restrictions](#) #enable-universal-tenant-restrictions

2. Las 12 trampas de M2

Memoriza la frase, entiende la regla, reconoce las palabras que delatan. Los números son para consultar, no para memorizar.

1 TAP: pase de entrada, no llave maestra

"La TAP es el pase de visitante: te deja registrar tu llave, pero no es tu llave."

- Se habilita en la Authentication methods policy y solo la usan los usuarios dentro del alcance. Vive de 10 minutos a 30 días, una por usuario, y con one-time el registro de passwordless se cierra a los 10 minutos.
- Authentication Administrator crea TAP a usuarios sin rol; Privileged Authentication Administrator también a admins. Nadie se crea una TAP a sí mismo, y no sirve con NPS extension ni con el adapter de AD FS.

Palabras que delatan: "new hires", "onboard passwordless", "lost their security key", "one-time use", "within 10 minutes", "holds an administrator role", "least privilege".

Learn: [howto-authentication-temporary-access-pass](#) #create-a-temporary-access-pass · Practica con Q1

2 Passkeys y Authenticator: dónde se configura cada cosa

"Passkey en Authenticator se configura en FIDO2, no en Authenticator. Y synced passkey con attestation no se llevan."

- Passkey profiles por grupo: tipo (device-bound o synced), enforce attestation y AAGUIDs (allow o block). Hasta 3 perfiles con el Default, y el opt-in no tiene regreso. Synced passkeys no soportan attestation.
- En la política de Microsoft Authenticator, el modo Passwordless es phone sign-in (no es passkey). El passkey de Authenticator es device-bound y se permite por AAGUID en Passkey (FIDO2).

Palabras que delatan: "synced passkeys", "iCloud Keychain", "Google Password Manager", "verify the make and model", "specific security key models", "pilot group", "passkeys in Microsoft Authenticator".

Learn: [how-to-authentication-passkeys-fido2](#) #passkey-profiles · Practica con Q3, Q4

3 CBA y authentication strengths: ¿es MFA? ¿es phishing-resistant?

"En CBA, policy OID le gana al issuer. En strengths, phone sign-in es passwordless pero NO phishing-resistant, y TAP solo llega a MFA."

- CBA: la CA va al trust store con CRL por HTTP (sin CRL no hay revocación); default single-factor y low affinity; con High affinity se caen PrincipalName y RFC822Name.
- Strengths built-in: MFA, Passwordless MFA y Phishing-resistant MFA (FIDO2, WHfB o platform credential, CBA multifactor). No se editan, y no mezclas Require MFA con Require authentication strength en la misma política.

Palabras que delatan: "smart card", "policy OID", "certificate issuer", "revoked certificate", "high affinity", "phishing-resistant", "only FIDO2 security keys", "specific key model".

Learn: [concept-authentication-strengths](#) #built-in-authentication-strengths · Practica con Q2, Q16, Q27

4 OAuth vs OATH, y cómo se controla la sesión

"OAuth es el token, OATH es el código de 6 dígitos. ¿Quieres forzar reauth? Sign-in frequency, no token lifetime."

- Refresh y session token lifetime ya no se configuran desde el 30 de enero de 2021. AccessTokenLifetime solo mueve access, ID y SAML tokens (10 minutos a 1 día), y el refresh token renueva en silencio.
- Persistent browser session exige All resources y le gana al "Stay signed in?" de branding. Remember MFA choca con sign-in frequency: apágalo antes.

Palabras que delatan: "re-enter credentials every X hours", "token lifetime policy", "MaxAgeMultiFactor", "must not stay signed in after closing the browser", "unmanaged devices", "OATH hardware token".

Learn: [configurable-token-lifetimes](#) #token-lifetime-policies-for-refresh-tokens-and-session-tokens-retired · Practica con Q5, Q21

5 Passwords: SSPR, writeback y password protection

"Writeback se prende en dos lados, los admins viven en two-gate, y en Audit el password malo pasa."

- SSPR: un solo grupo en Selected desde el portal, 1 o 2 métodos. Admins con two-gate fijo (sin security questions). Writeback pide P1 y se activa en el wizard de Connect y en On-premises integration; no se garantiza con staged rollout.
- Password protection: custom list de hasta 1000 términos de 4 a 16 caracteres. On-prem: proxy en server del dominio, DC agent en todos los DCs (con reboot), DCs sin internet. Audit registra y acepta; Enforced rechaza.

Palabras que delatan: "contact your administrator", "synchronized users can't reset", "Helpdesk Administrator can't use security questions", "some domain controllers", "Audit mode", "no internet access from domain controllers".

Learn: [howto-password-ban-bad-on-premises-operations](#) #modes-of-operation · Practica con Q7, Q8, Q11

6 Kerberos en la nube: WHfB y Azure Files

"Cloud Kerberos trust: cero PKI. Entra Kerberos en Azure Files: cero MFA para esa app."

- WHfB híbrido sin certificados: crear el objeto Microsoft Entra Kerberos (Set-AzureADKerberosServer), activar "Use cloud trust for on-premises authentication" y enrolar con línea de vista al DC la primera vez. Si "Use certificate for on-premises authentication" está activo, gana certificate trust.
- Azure Files: habilitar Entra Kerberos en el storage account, admin consent a la app y clientes con CloudKerberosTicketRetrievalEnabled. Un solo identity source por storage account, y la app del storage se excluye de las políticas de MFA.

Palabras que delatan: "no PKI", "must not deploy certificates", "SSO to on-premises file shares", "FSLogix", "Azure Virtual Desktop", "profile containers fail to mount after an MFA policy".

Learn: [kerberos](#) #mfa-incompatibility-for-azure-files-authentication · Practica con Q9, Q12

7 Planear y probar CA sin logout

"Si nadie dice que no, Entra dice que sí. Para 'solo Finance' necesitas un block, y antes de todo, apaga security defaults."

- Security defaults y CA no conviven. Si ninguna política dispara un control, el token se emite. Excluye break-glass siempre; los templates nacen en report-only y solo excluyen a quien los crea.
- What If evalúa solo políticas On o report-only y no ve service dependencies. Report-only no sirve para User Actions (Register security information, Register or join devices).

Palabras que delatan: "security defaults are enabled", "only members of Finance", "users outside the group can access", "without affecting users", "from a template", "emergency access accounts", "Register or join devices".

Learn: [plan-conditional-access](#) #combining-policies · Practica con Q13, Q14, Q19, Q20, Q26, Q28

8 Assignments y device-enforced restrictions

"Excluye el PAW y bloquea el resto: un device no registrado es null, y null no se excluye."

- Directory roles en CA: solo built-in, nada con scope de AU ni custom roles. Guests: eliges tipo de usuario externo y tenant específico.
- Filter for devices: operadores positivos no aplican a devices no registrados, los negativos sí; extensionAttributes piden Intune, compliant o hybrid. App enforced restrictions da acceso limitado en SharePoint y Exchange sin productos extra.

Palabras que delatan: "privileged access workstation", "extensionAttribute", "unregistered devices must be blocked", "limited browser-only access", "no additional products", "guests from a specific partner".

Learn: [concept-condition-filters-for-devices](#) #policy-behavior-with-filter-for-devices · Practica con Q15, Q17, Q18

9 CAE y revocar sesiones

"CAE corta por eventos, no por cambios de grupo, y solo entiende IPs, no países. Revoke sessions es tu botón de 'ahora mismo'."

- Eventos críticos: cuenta deshabilitada o borrada, password cambiado o reseteado, MFA habilitado, revoke de refresh tokens y high user risk. Hasta 15 minutos; tokens de hasta 28 horas. Guests no.
- Cambios de grupo o de política tardan hasta un día. Híbrido: deshabilitar en AD, reset doble, Revoke-MgUserSignInSession y deshabilitar devices; sin CAE el access token vive hasta expirar.

Palabras que delatan: "near real time", "terminated employee", "account is synchronized", "country location", "added to an excluded group", "immediately".

Learn: [concept-continuous-access-evaluation](#) #critical-event-evaluation · Practica con Q10, Q22

10 Authentication context, protected actions y PIM

"El context es la etiqueta, la policy pone las reglas, y el que la pega es SharePoint, PIM o protected actions. Y la policy va en On, no en report-only."

- Authentication context: c1 a c99 con Publish to apps; SharePoint lo pega con sensitivity label o Set-SPOSite; PIM lo pide al activar (sin mezclarlo con el directory role en la misma política).
- Protected actions: CA sobre permisos (CA policies, named locations, cross-tenant settings, hard delete) sin importar el rol. Lo configura CA Admin o Security Admin; Azure PowerShell falla, Graph PowerShell no.

Palabras que delatan: "specific SharePoint site", "at the moment of activation", "regardless of the role", "when administrators modify Conditional Access policies", "step-up", "Publish to apps".

Learn: [protected-actions-overview](#) #what-permissions-can-be-used-with-protected-actions · Practica con Q23, Q24, Q25, Q27

11 Riesgo: quién se cura con qué

"User risk se cura con password (o risk remediation); sign-in risk se cura con MFA. Nunca al revés y nunca en la misma policy."

- Require risk remediation cubre usuarios con password y passwordless, y agrega auth strength y SIF Every time. Políticas basadas en riesgo piden P2; las legacy de ID Protection se retiran el 1 de octubre de 2026. Report suspicious activity pone High user risk.
- Registro: MFA registration policy (14 días) y campaign (un método a la vez, Authenticator en Any o Push, 3 snoozes). Workload identities: CA de riesgo pide Workload Identities Premium, solo single-tenant, sin MFA posible.

Palabras que delatan: "users at risk", "leaked credentials", "passwordless users", "self-remediate", "nudge users", "snooze", "service principal", "managed identity", "least privilege to dismiss risk".

Learn: [concept-identity-protection-policies](#) #require-risk-remediation-control · Practica con Q6, Q29, Q30, Q31, Q32, Q33, Q34, Q35, Q36, Q37, Q38

12 Global Secure Access en un dibujo

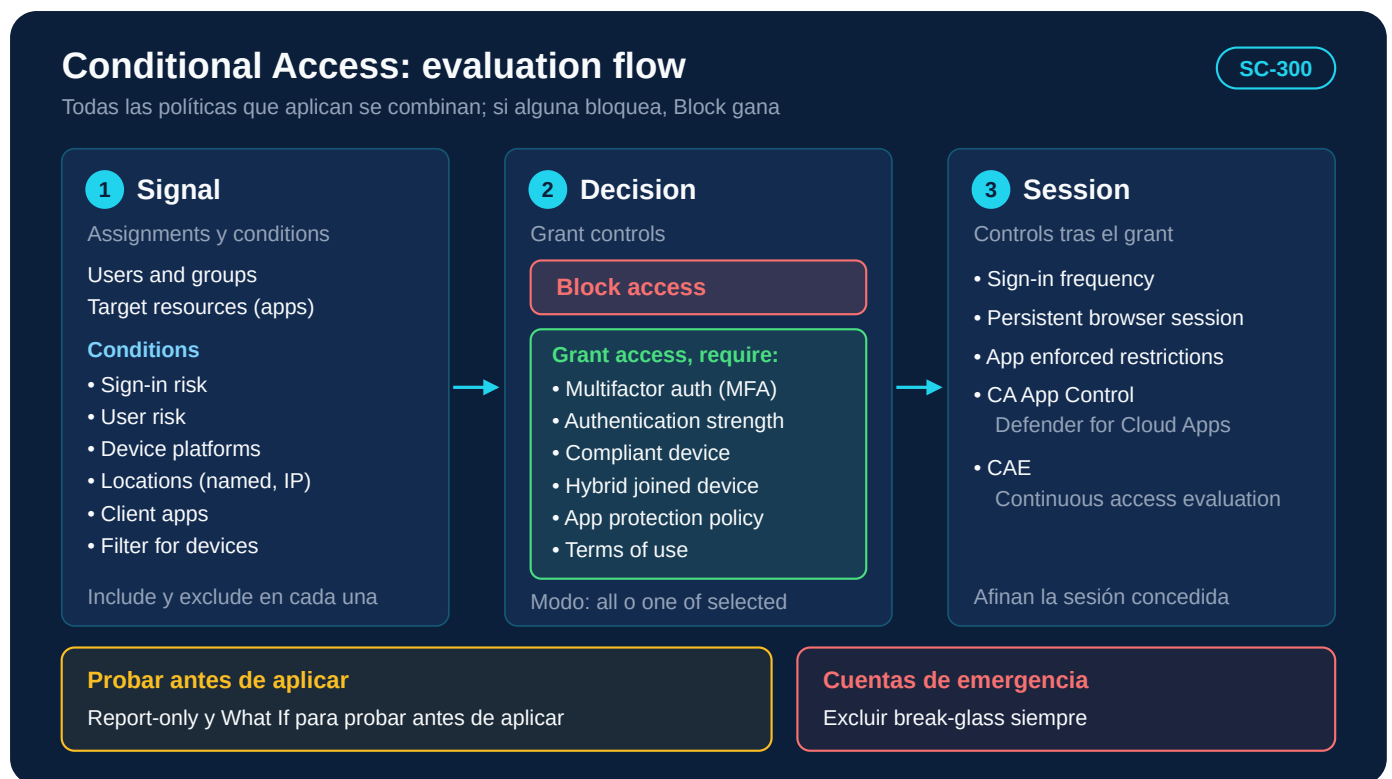
"Microsoft primero, luego Private, luego Internet. Private Access mata la VPN, compliant network mata el token robado, y tenant restrictions cierra la puerta a otros tenants."

- Cliente Windows: joined, hybrid o registered (registered solo Private Access); sin AVD multi-session; apagar QUIC y DNS over HTTPS. Private Access: connector, Quick Access, asignar sin nested groups, habilitar el profile; per-app access para CA distinto.
- Internet Access: filtering policy, security profile y CA con "All internet resources with Global Secure Access". Microsoft traffic profile (P1): compliant network check, universal tenant restrictions (TRv2) y source IP restoration.

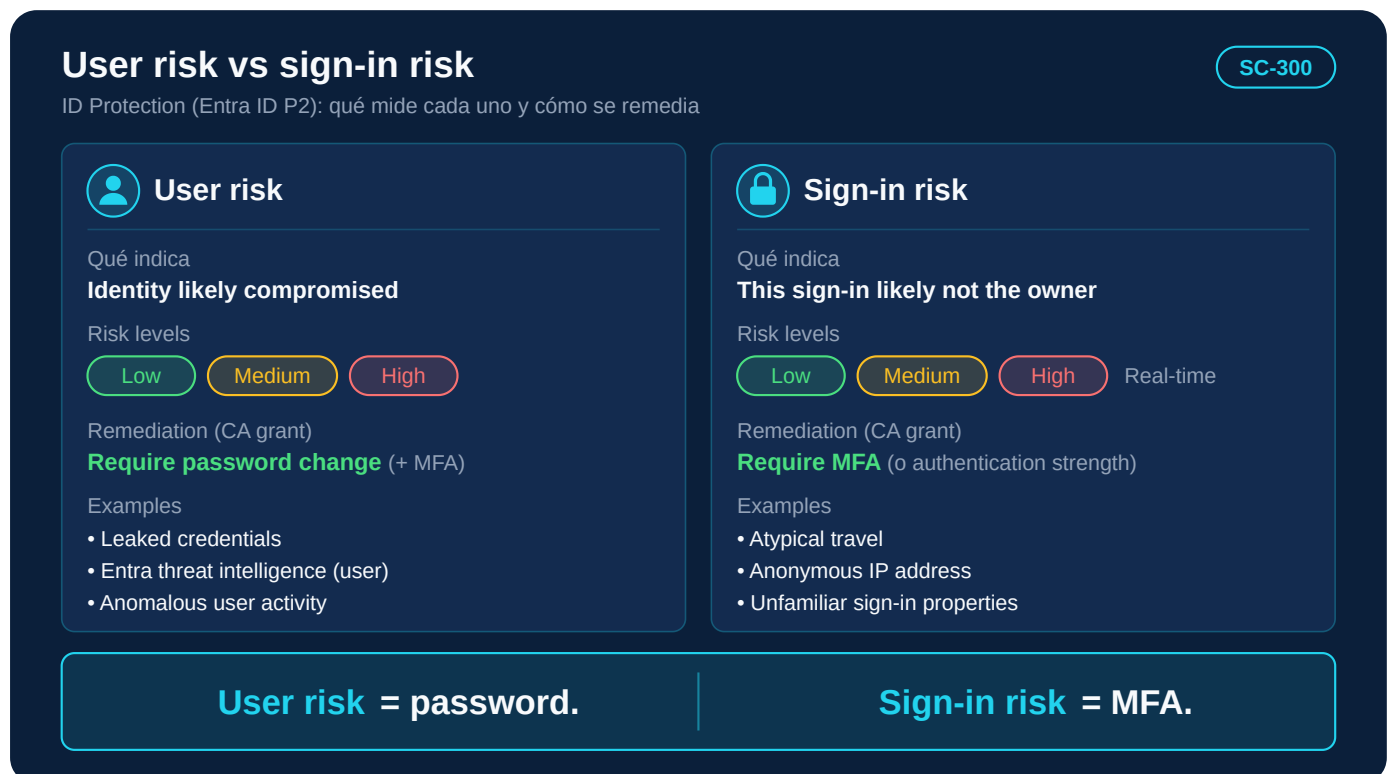
Palabras que delatan: "replace the VPN", "different Conditional Access for one app", "block a web category for one group", "stolen tokens replayed", "without maintaining IP lists", "sign in to other tenants", "real public IP in sign-in logs".

Learn: [concept-traffic-forwarding](#) #traffic-forwarding · Practica con Q39, Q40, Q41, Q42, Q43, Q44

3. Visuales para no olvidar



Cómo evalúa Conditional Access. Señales, decisión y sesión. Si ninguna política dispara un control, el token se emite. Report-only y What If para probar; break-glass siempre excluido.



Riesgo. User risk se cura con password o Require risk remediation; sign-in risk se cura con MFA. Nunca al revés y nunca en la misma policy. Las legacy se retiran el 1 de octubre de 2026.

4. Banco de preguntas: 44 preguntas estilo examen

En inglés, como el examen. Contesta sin ver la sección 5. En las series Yes/No cada afirmación se evalúa sola; en drag/order solo cuentan las acciones que sí van, en orden. Los case studies aplican a las dos preguntas que los siguen.

Subdominio 1: Plan, implement, and manage Microsoft Entra user authentication

Q1 **Yes/No series** Implement and manage authentication methods (Temporary Access Pass)

Contoso enables the Temporary Access Pass (TAP) method in the Authentication methods policy and targets it to a group named NewHires. The TAP settings are: default lifetime 1 hour, maximum lifetime 8 hours, and one-time use set to Yes. Sam is assigned only the Authentication Administrator role.

For each of the following statements, select Yes or No.

1. Sam can create a TAP for Ana, a member of NewHires who holds the Helpdesk Administrator role.
2. Sam can create a TAP for Luis, a contractor who isn't a member of NewHires, but Luis can't use it to sign in.
3. A new hire who signs in with a TAP to register a FIDO2 security key must finish the registration within 10 minutes of that sign-in.

Q2 **Yes/No series** Implement and manage authentication methods (certificate-based authentication)

Fabrikam enables Microsoft Entra certificate-based authentication (CBA) for a group named SmartCardUsers. A Privileged Authentication Administrator uploaded the issuing CA (CN=FabrikamIssuing) to the PKI-based trust store but left the Certificate Revocation List URL empty.

The authentication binding policy is configured as follows:

- Default protection level: Single-factor authentication
- Rule 1: Certificate issuer CN=FabrikamIssuing, protection level Single-factor authentication
- Rule 2: Policy OID 1.3.6.1.4.1.311.21.8.5, protection level Multifactor authentication

The username binding policy uses the default mapping of PrincipalName to userPrincipalName.

For each of the following statements, select Yes or No.

1. If a user's certificate is revoked on the issuing CA, the user can still sign in with that certificate.
2. A certificate issued by CN=FabrikamIssuing that contains policy OID 1.3.6.1.4.1.311.21.8.5 satisfies a Conditional Access policy that requires multifactor authentication.
3. If you set Required affinity binding to High at the tenant level, users can keep signing in with the current username binding.

Q3 Multiple choice Implement and manage authentication methods (passkeys FIDO2)

Contoso is deploying passkeys (FIDO2). The requirements are:

- Members of the IT-Admins group must use only device-bound passkeys on two approved FIDO2 security key models, and Microsoft Entra ID must verify the make and model at registration.
- Members of the HR group must be able to register synced passkeys stored in iCloud Keychain or Google Password Manager.
- Administrative effort must be minimized.

What should you do?

- A. Keep a single Passkey (FIDO2) configuration for all users with Enforce attestation set to Yes and key restrictions that allow only the AAGUIDs of the two approved models.
- B. Opt in to passkey profiles. Create a profile for IT-Admins with passkey type Device-bound, Enforce attestation set to Yes, and key restrictions that allow the two AAGUIDs. Create a second profile for HR with passkey types Device-bound and Synced, and Enforce attestation set to No.
- C. Enable the Microsoft Authenticator method for HR with Authentication mode set to Passwordless, and enable Passkey (FIDO2) only for IT-Admins.
- D. Leave the Passkey (FIDO2) method with its default settings and create a Conditional Access policy that requires the built-in Phishing-resistant MFA authentication strength for IT-Admins.

Q4 Multiple choice Implement and manage authentication methods (Microsoft Authenticator)

Contoso wants a pilot group named Pilot-PK to sign in with passkeys stored in Microsoft Authenticator on their phones. All other users must keep using Authenticator push notifications for MFA and must not be able to register passkeys in Authenticator.

What should you configure?

- A. In the Microsoft Authenticator method policy, target Pilot-PK and set Authentication mode to Passwordless.
- B. In the Passkey (FIDO2) method policy, use passkey profiles: one profile for Pilot-PK that is Device-bound and allows the Microsoft Authenticator AAGUIDs, and one profile for all other users that blocks the Microsoft Authenticator AAGUIDs.
- C. Create a registration campaign that targets Pilot-PK with Microsoft Authenticator as the authentication method.
- D. Create a Conditional Access policy for Pilot-PK that requires the built-in Passwordless MFA authentication strength.

Q5 **Multiple choice** Implement and manage authentication methods (OAuth 2.0 tokens)

For a finance web app, Contoso's security team requires that users re-enter their credentials at least every 8 hours. A colleague proposes creating a token lifetime policy with MaxAgeMultiFactor set to 08:00:00 and assigning it to the app.

What should you do?

- A. Create and assign the token lifetime policy as proposed.
- B. Create a token lifetime policy with AccessTokenLifetime set to 08:00:00 and assign it to the app.
- C. Create a Conditional Access policy that targets the app and sets the Sign-in frequency session control to 8 hours.
- D. Enable Remember multifactor authentication on trusted devices in the MFA service settings.

Q6 **Yes/No series** Implement and manage tenant-wide multifactor authentication (MFA) settings

Contoso has Microsoft Entra ID P1 licenses only. An Authentication Policy Administrator sets Report suspicious activity to Enabled for all users in Authentication methods > Settings. The legacy MFA service settings contain a trusted IP range for the head office public IP address.

For each of the following statements, select Yes or No.

1. When a user reports an unexpected MFA prompt as suspicious, the user is set to high user risk.
2. Contoso can use a user risk-based Conditional Access policy to block the reporting users automatically.
3. Contoso can add the internal range 10.10.0.0/16 to trusted IPs so that users on the LAN skip MFA prompts.

Q7 **Select two** Configure and deploy self-service password reset (SSPR)

Contoso synchronizes users from AD DS by using Microsoft Entra Connect Sync with password hash synchronization. Contoso has Microsoft Entra ID P1. SSPR is enabled for all users, and users have registered their methods. Cloud-only users can reset their passwords, but synchronized users see a message telling them to contact their administrator.

You need to ensure that synchronized users can reset their passwords by using SSPR.

Which two actions should you perform? Each correct answer presents part of the solution.

- A. Run the Microsoft Entra Connect wizard, select Customize synchronization options, and select Password writeback on the Optional features page.
- B. In the Microsoft Entra admin center, go to Password reset > On-premises integration and select Write back passwords to your on-premises directory.
- C. Enable staged rollout for the synchronized users.
- D. Enable seamless single sign-on in Microsoft Entra Connect.
- E. Change Number of methods required to reset to 2.

Q8 Multiple choice Configure and deploy self-service password reset (SSPR)

Contoso enables SSPR for a group named SSPR-Users by selecting Selected in the Password reset properties. Number of methods required to reset is set to 1, and the available methods are Mobile phone, Email, and Security questions.

Megan is a member of SSPR-Users and holds the Helpdesk Administrator role. She registered only security questions. She can't reset her password by using SSPR, while standard users who registered only security questions can.

What is the cause?

- A. SSPR is disabled for administrator accounts by default.
- B. Administrator accounts use a two-gate policy that requires two methods and doesn't allow security questions, and the policy can't be changed.
- C. Megan must be added to SSPR-Users directly because nested groups aren't supported.
- D. The tenant must migrate to the Authentication methods policy before security questions can be used.

Q9 Drag/order Implement and manage Windows Hello for Business

Contoso has Microsoft Entra hybrid joined Windows 11 devices and uses password hash synchronization. Contoso doesn't have an enterprise PKI. Users must sign in with Windows Hello for Business and get single sign-on to on-premises file shares. The solution must not require deploying certificates.

Which three actions should you perform in sequence? (Two actions aren't used.)

- A. Deploy AD FS as a certificate registration authority and issue authentication certificates to users.
- B. On the Microsoft Entra Connect server, install the AzureADHybridAuthenticationManagement module and run Set-AzureADKerberosServer to create the Microsoft Entra Kerberos server object in each domain.
- C. Deploy a Group Policy or Intune policy that enables Use Windows Hello for Business and Use cloud trust for on-premises authentication.
- D. Have each user sign in to the device while it has line of sight to a domain controller and complete Windows Hello for Business provisioning.
- E. Enable the Use certificate for on-premises authentication policy setting.

Q10 Drag/order Disable accounts and revoke user sessions

A Contoso employee is terminated effective immediately and might try to access company data. The account is synchronized from on-premises AD DS by Microsoft Entra Connect Sync, and the user has a Microsoft Entra joined laptop. You must follow Microsoft guidance for hybrid environments.

Which four actions should you perform in sequence? (Two actions aren't used.)

- A. Disable the account in AD DS by running Disable-ADAccount.
- B. Reset the user's password twice in AD DS by running Set-ADAccountPassword.
- C. Revoke the user's refresh tokens by running Revoke-MgUserSignInSession.
- D. Disable the user's registered devices by running Update-MgDevice with -AccountEnabled:\$false.
- E. Delete the user from Microsoft Entra ID.
- F. Require the user to re-register for multifactor authentication.

Q11 Yes/No series Implement and manage Microsoft Entra password protection

Contoso has one AD DS domain with 10 domain controllers and Microsoft Entra ID P1 licenses. You install the Microsoft Entra Password Protection proxy service on two member servers and register the proxy and the forest. You install the DC agent on 4 of the 10 domain controllers and restart them.

In the Microsoft Entra admin center, Enable password protection on Windows Server Active Directory is set to Yes and Mode is set to Audit. The custom banned password list contains Contoso and Seattle.

For each of the following statements, select Yes or No.

1. A user who changes the password to C0ntos0Seattle! on a domain controller that runs the DC agent receives an error, and the password isn't changed.
2. Password changes processed by the six domain controllers without the DC agent aren't validated against the banned password lists.
3. The domain controllers that run the DC agent need outbound internet access to download the password policy.

Q12 Multiple choice Enable Microsoft Entra Kerberos authentication for hybrid identities

Contoso uses Azure Virtual Desktop with Microsoft Entra joined session hosts and stores FSLogix profile containers in Azure Files. Users are hybrid identities synchronized by Microsoft Entra Connect Sync. You enabled Microsoft Entra Kerberos on the storage account, granted admin consent to the storage account application, and configured the session hosts with CloudKerberosTicketRetrievalEnabled.

Everything worked until a new Conditional Access policy that requires MFA for All resources was turned on. Now profile containers fail to mount, while other apps work.

What should you do?

- A. Exclude the storage account application from the Conditional Access policy that requires MFA.
- B. Enable on-premises AD DS authentication on the same storage account as a second identity source.
- C. Add the kdc_enable_cloud_group_sids tag to the storage account application manifest.
- D. Configure a host name to Kerberos realm mapping on the session hosts.

Subdominio 2: Plan, implement, and manage Microsoft Entra Conditional Access

Q13 **Multiple choice** Plan Conditional Access policies

Contoso's Microsoft Entra tenant was created in 2023 and has security defaults enabled. The company buys Microsoft Entra ID P1 licenses for all users. The new requirements are:

- Users must perform MFA only when they access the Payroll app from outside the office.
- A service account used by a multifunction printer must be excluded from MFA.

You need to implement the requirements by using Conditional Access. What should you do first?

- A. Create the Conditional Access policies and turn them on. Security defaults are disabled automatically.
- B. Disable security defaults.
- C. Enable per-user MFA for all users.
- D. Add the office public IP range to trusted IPs in the MFA service settings.

Q14 **Multiple choice** Plan Conditional Access policies

Contoso has a Conditional Access policy named CA01 that is turned on:

- Users: include the Finance group
- Target resources: Payroll
- Grant: Require multifactor authentication

Users outside Finance can open Payroll without any prompt. Only Finance users must be able to access Payroll. You must use only Conditional Access, and emergency access accounts must not be blocked.

What should you do?

- A. Change CA01 to include All users.
- B. Create CA02: include All users, exclude Finance and the emergency access accounts, target Payroll, and select Block access. Turn CA02 on.
- C. In CA01, change the grant setting to Require one of the selected controls.
- D. Create CA02 in Report-only: include All users, target Payroll, and select Block access.

Q15 **Multiple choice** Implement Conditional Access policy assignments

Contoso collaborates with two partners, Fabrikam and Tailspin, by using B2B collaboration. Guests from Fabrikam must perform MFA when they access Contoso's SharePoint Online. Guests from Tailspin must not be affected by this policy.

What should you configure in the Users assignment of the policy?

- A. Include > Select users and groups > Guest or external users > B2B collaboration guest users, and then specify Fabrikam's Microsoft Entra tenant.
- B. Include > Directory roles > Guest Inviter.
- C. Include a dynamic group with the membership rule (user.userType -eq "Guest").
- D. Include All users, and exclude Guest or external users with all external user types selected.

Q16 **Select two** Implement Conditional Access policy controls

Contoso has a Conditional Access policy that targets administrator roles with the grant control Require authentication strength set to the built-in Phishing-resistant MFA strength. Administrators currently sign in with the following methods:

- FIDO2 security key
- Certificate-based authentication with certificates mapped to multifactor in the authentication binding policy
- Microsoft Authenticator phone sign-in
- Temporary Access Pass
- Password plus Microsoft Authenticator push notification

Which two methods satisfy the policy? Each correct answer presents a complete solution.

- A. FIDO2 security key
- B. Certificate-based authentication (multifactor)
- C. Microsoft Authenticator phone sign-in
- D. Temporary Access Pass
- E. Password plus Microsoft Authenticator push notification

Q17 **Multiple choice** Implement device-enforced restrictions

Contoso requirements for SharePoint Online and Exchange Online:

- Users on unmanaged devices can use only the browser, with a limited experience (for example, no download or sync).
- Users on compliant or Microsoft Entra hybrid joined devices get full access.
- Administrative effort must be minimized, and no additional products can be deployed.

What should you configure in Conditional Access?

- A. A grant control that requires the device to be marked as compliant for SharePoint Online and Exchange Online.
- B. The session control Use app enforced restrictions for SharePoint Online and Exchange Online, with limited access configured in those services.
- C. The session control Use Conditional Access App Control with a Microsoft Defender for Cloud Apps session policy that blocks downloads.
- D. A filter for devices condition that excludes devices with trustType equal to AzureAD, with the grant control Block access.

Q18 Multiple choice Implement device-enforced restrictions

Administrators must access the Windows Azure Service Management API only from privileged access workstations (PAWs). PAWs are Intune managed, compliant, and have device.extensionAttribute1 set to "PAW". Access from any other device, including devices that aren't registered in Microsoft Entra ID, must be blocked.

Which Conditional Access policy should you create for the administrator roles?

- A. Target resource: Windows Azure Service Management API. Filter for devices: include filtered devices, rule device.extensionAttribute1 -eq "PAW". Grant: Block access.
- B. Target resource: Windows Azure Service Management API. Filter for devices: exclude filtered devices, rule device.extensionAttribute1 -eq "PAW". Grant: Block access.
- C. Target resource: Windows Azure Service Management API. Filter for devices: include filtered devices, rule device.extensionAttribute1 -eq "PAW". Grant: Require multifactor authentication.
- D. Target resource: Microsoft Admin Portals. Device platforms: include Windows. Grant: Require Microsoft Entra hybrid joined device.

Q19 Yes/No series Test and troubleshoot Conditional Access policies

A user reports that she's prompted for MFA in Microsoft Teams, and you don't know which policy causes it. You open the Conditional Access What If tool.

For each of the following statements, select Yes or No.

1. What If evaluates policies whose state is Off, so you can see what would happen if you turned them on.
2. If you simulate access to Microsoft Teams, the result also lists the policies that apply to Exchange Online and SharePoint Online because Teams depends on them.
3. For each policy that doesn't apply, What If shows the first condition that wasn't satisfied.

Q20 Multiple choice Test and troubleshoot Conditional Access policies

You plan a Conditional Access policy that requires MFA for the user action Register or join devices. Before you enforce it, you need to verify whether the policy would apply to a specific test user who is also covered by several other policies. No user must be prompted during the verification.

What should you use?

- A. Set the policy to Report-only and review the Report-only tab in the sign-in logs.
- B. The What If tool, with the Register or join devices user action selected.
- C. The Conditional Access insights and reporting workbook.
- D. The Policy impact view for the new policy.

Q21 **Select two** Implement session management

On devices that aren't compliant, users must not stay signed in after they close the browser. Users on compliant devices must not be affected. You create a Conditional Access policy that uses a filter for devices to exclude compliant devices.

Which two settings must the policy include? Each correct answer presents part of the solution.

- A. Target resources: All resources.
- B. Session: Persistent browser session set to Never persistent.
- C. Target resources: Office 365 only.
- D. Session: Sign-in frequency set to Every time.
- E. In Company branding, set Show option to remain signed in to No.

Q22 **Yes/No series** Implement continuous access evaluation

Contoso has a Conditional Access policy that allows Exchange Online and SharePoint Online only from a named location named HQ-IPs. HQ-IPs contains all IPv4 and IPv6 egress ranges seen by Microsoft Entra ID and by the resources. Continuous access evaluation (CAE) isn't disabled. Users run the latest Outlook desktop client.

For each of the following statements, select Yes or No.

1. If an administrator disables a user account, the user loses access to Exchange Online in Outlook in near real time instead of waiting for the access token to expire.
2. If you replace HQ-IPs with a country or region location for the United States, CAE still enforces the location instantly when a user travels to another country.
3. If you add a user to a group that's excluded from a Conditional Access policy, Exchange Online applies the change immediately.

Q23 Drag/order Configure authentication context

The SharePoint Online site named Legal-Confidential must require a compliant device and phishing-resistant MFA. Other SharePoint sites must not be affected. Contoso already has the Microsoft Purview licensing required, and sensitivity labels for groups and sites are enabled.

Which four actions should you perform in sequence? (Two actions aren't used.)

- A. In Conditional Access > Authentication context, create an authentication context named Sensitive sites and select Publish to apps.
- B. Create a Conditional Access policy whose target resource is the Sensitive sites authentication context, with grant controls Require device to be marked as compliant and Require authentication strength (Phishing-resistant MFA). Turn the policy on.
- C. In Microsoft Purview, edit a sensitivity label for groups and sites, select Use Microsoft Entra Conditional Access to protect labeled SharePoint sites, and choose the Sensitive sites authentication context.
- D. Apply the sensitivity label to the Legal-Confidential site.
- E. Create a Conditional Access policy that targets <https://contoso.sharepoint.com/sites/Legal-Confidential> as a cloud app.
- F. Create a named location for the Legal department office.

Q24 Multiple choice Configure authentication context

Users who are eligible in Privileged Identity Management (PIM) for the Exchange Administrator role must use phishing-resistant MFA from a compliant device at the moment they activate the role. The requirement must apply at activation, not at every sign-in.

What should you do?

- A. In the PIM role settings for Exchange Administrator, enable On activation, require multifactor authentication.
- B. Create an authentication context and a Conditional Access policy that targets it, scoped to all users or the eligible users, with grant controls for a compliant device and the Phishing-resistant MFA strength. Then, in the PIM role settings, select On activation, require Microsoft Entra Conditional Access authentication context and choose that context.
- C. Create a Conditional Access policy that includes the Exchange Administrator directory role and targets the authentication context used by PIM.
- D. Add a protected action to the permission that assigns directory roles.

Q25 Yes/No series Implement protected actions

Contoso creates and publishes an authentication context named c5 Protected CA changes. It creates a Conditional Access policy that targets c5, requires the built-in Phishing-resistant MFA strength, excludes the emergency access accounts, and leaves the policy in Report-only while testing. A Security Administrator then adds protected actions for `microsoft.directory/conditionalAccessPolicies/basic/update` and `microsoft.directory/conditionalAccessPolicies/delete` by using c5.

For each of the following statements, select Yes or No.

1. The Security Administrator role has enough permissions to add the protected actions.
2. While the c5 policy is in Report-only, an administrator who completes phishing-resistant MFA can edit Conditional Access policies without issues.
3. An administrator who uses Azure PowerShell can delete a Conditional Access policy after satisfying the step-up prompt.

Q26 Multiple choice Create a Conditional Access policy from a template

Carlos, a Conditional Access Administrator, creates a policy from the template Require phishing-resistant multifactor authentication for administrators. Contoso has two cloud-only emergency access accounts that hold the Global Administrator role and don't have phishing-resistant methods.

What should Carlos do before he sets the policy to On?

- A. Nothing. Templates automatically exclude emergency access accounts.
- B. Edit the policy and exclude the two emergency access accounts, because the template excludes only the user who created the policy.
- C. Change the policy state from Off to Report-only, because templates create policies in the Off state.
- D. Export the template JSON, add the exclusions, and create the policy again with Upload policy file, because template policies can't be edited.

Case study 1: Adatum Corporation (usar para Q27 y Q28)

Adatum Corporation has 4,000 users. Every user has a Microsoft 365 E3 license (which includes Microsoft Entra ID P1) and the Microsoft 365 E5 Compliance add-on. Adatum doesn't have Microsoft Entra ID P2. Security defaults are disabled, and Adatum has 30 Conditional Access policies. There are two cloud-only emergency access accounts.

Requirements:

- R1: Any creation, change, or deletion of a Conditional Access policy or a named location must require the administrator to use a FIDO2 security key at the moment of the change, regardless of which role grants the permission.
- R2: Access to the SharePoint site named Board must require a compliant device.
- R3: When Microsoft detects that a user's credentials were leaked, the user must be forced automatically to change the password at the next sign-in.
- R4: Users on unmanaged devices must get limited, browser-only access to Exchange Online.
- Administrative effort and cost must be minimized.

Q27 Case study (Multiple choice) Implement protected actions

Refer to Case study 1. Which solution meets R1?

- A. Create an authentication context and a Conditional Access policy (turned on) that targets it with a custom authentication strength that allows only passkeys (FIDO2) restricted to the approved security key AAGUIDs. Then, in Roles & admins > Protected actions, assign the context to the create, update, and delete permissions of Conditional Access policies and named locations.
- B. Create a Conditional Access policy that includes the Conditional Access Administrator directory role, targets Microsoft Admin Portals, and requires the Phishing-resistant MFA strength.
- C. Configure PIM for the Conditional Access Administrator role with On activation, require multifactor authentication.
- D. Create a custom role without Conditional Access permissions and assign it to all administrators.

Q28 Case study (Multiple choice) Plan Conditional Access policies

Refer to Case study 1. Which requirement can't be met with Adatum's current licenses?

- A. R1
- B. R2
- C. R3
- D. R4

Subdominio 3: Manage risk by using Microsoft Entra ID Protection

Q29 Multiple choice

Implement and manage user risk by using Microsoft Entra ID Protection or Conditional Access policies

Contoso has Microsoft Entra ID P2. Some users sign in with passwords, and others are passwordless (Windows Hello for Business and passkeys). The legacy user risk policy in ID Protection is enabled with Require password change.

You need a user risk solution that lets both groups self-remediate when user risk is High and that follows Microsoft recommendations before the legacy risk policies are retired.

What should you do?

- A. Keep the legacy ID Protection user risk policy and add Require multifactor authentication to it.
- B. Create a Conditional Access policy for All users (excluding emergency access accounts) and All resources, with the condition User risk set to High and the grant control Require risk remediation. Then disable the legacy user risk policy.
- C. Create a Conditional Access policy with the condition User risk set to High and the grant control Require multifactor authentication.
- D. Create a Conditional Access policy with the conditions User risk High and Sign-in risk High and the grant control Require password change.

Q30 Yes/No series

Implement and manage sign-in risk by using Microsoft Entra ID Protection or Conditional Access policies

Contoso creates the following Conditional Access policy:

- Users: All users, excluding emergency access accounts
- Target resources: All resources
- Conditions: Sign-in risk set to Medium and High
- Grant: Require authentication strength (built-in Multifactor authentication)
- Session: Sign-in frequency set to Every time

For each of the following statements, select Yes or No.

1. A user who hasn't registered any MFA method and triggers a medium-risk sign-in is blocked and needs an administrator to intervene.
2. When a user completes MFA on a risky sign-in, the risk state of that sign-in changes to Remediated.
3. To reduce the number of policies, you should add the User risk High condition to this same policy.

Q31 Multiple choice

Implement and manage user risk by using Microsoft Entra ID Protection or Conditional Access policies

Contoso is a hybrid organization that uses password hash synchronization. Many users work on Microsoft Entra hybrid joined devices and change their passwords on-premises by pressing Ctrl+Alt+Del. When these users are flagged with user risk, the risk stays At risk after they change their password on-premises.

You need on-premises password changes to remediate user risk. What should you do?

- A. Enable password writeback in Microsoft Entra Connect.
- B. In ID Protection settings, select Allow on-premises password change to reset user risk.
- C. Enable SSPR for all users.
- D. Dismiss the user risk for all risky users every week.

Q32 Multiple choice

Implement and manage multifactor authentication registration by using authentication methods and registration campaigns

Contoso users perform MFA with text messages (SMS). You create a registration campaign with the following settings: State Enabled, Authentication method Microsoft Authenticator, include All users, Days allowed to snooze 3, and Limited number of snoozes Enabled. After a week, no user has been prompted.

In the Microsoft Authenticator method policy, All users are targeted and Authentication mode is set to Passwordless.

What should you change?

- A. Set Days allowed to snooze to 0.
- B. Set the Authenticator Authentication mode to Any or Push.
- C. Change the campaign state to Microsoft managed.
- D. Enable the multifactor authentication registration policy in ID Protection.

Q33 Yes/No series

Implement and manage multifactor authentication registration by using authentication methods and registration campaigns

Contoso has Microsoft Entra ID P2. It enables the ID Protection multifactor authentication registration policy for all users and also runs a registration campaign in the Enabled state with Limited number of snoozes set to Enabled.

For each of the following statements, select Yes or No.

1. With the ID Protection MFA registration policy, users have 14 days to register, and after that they must register before they can complete sign-in.
2. A single registration campaign can nudge users to set up Microsoft Authenticator and a passkey at the same time.
3. With Limited number of snoozes enabled, a user can skip the campaign prompt three times before registration becomes required.

Q34 Select two Monitor, investigate and remediate risky users and risky sign-ins

A security analyst must be able to dismiss user risk and generate temporary passwords for users directly from ID Protection > Risky users. The solution must follow the principle of least privilege.

Which two roles should you assign? Each correct answer presents part of the solution.

- A. Security Reader
- B. Security Operator
- C. User Administrator
- D. Security Administrator
- E. Global Reader

Q35 Multiple choice Monitor, investigate and remediate risky users and risky sign-ins

ID Protection flags an Atypical travel detection for Diego: one sign-in from Mexico City and, 20 minutes later, one from Frankfurt. Your investigation shows that the Frankfurt IP address is the egress IP of Contoso's sanctioned corporate VPN. Several users get similar detections every week.

What should you do?

- A. Confirm the sign-in as compromised and reset Diego's password.
- B. Confirm the sign-in as safe, and add the VPN egress IP range to named locations in Microsoft Entra ID and in Microsoft Defender for Cloud Apps.
- C. Dismiss Diego's user risk and exclude Diego from the sign-in risk policy.
- D. Turn off the Atypical travel detection in ID Protection settings.

Q36 Multiple choice Monitor, investigate and remediate risky users and risky sign-ins

Contoso has Microsoft Entra ID P1 (no P2) and uses password hash synchronization. The Risky users report shows Adele with a Leaked credentials detection.

Which action remediates the user risk for this detection?

- A. Dismiss Adele's user risk.
- B. Reset Adele's password in Microsoft Entra ID, for example by generating a temporary password.
- C. Require MFA at Adele's next sign-in.
- D. Revoke Adele's sessions.

Q37 Multiple choice Monitor, investigate, and remediate risky workload identities

Contoso has Microsoft Entra ID P2 for all users. A single-tenant app registration named InvoiceSync authenticates with a client secret. You need to block sign-ins from the InvoiceSync service principal automatically whenever ID Protection flags it as high risk.

What do you need?

- A. Nothing more than P2. Create a Conditional Access policy that targets the service principal with the service principal risk condition and Block access.
- B. Workload Identities Premium licenses, and then a Conditional Access policy that targets the InvoiceSync service principal with the service principal risk condition set to High and the grant control Block access.
- C. A Conditional Access policy that targets the service principal and requires MFA when risk is High.
- D. A user risk-based Conditional Access policy that includes the owner of the app registration.

Q38 Select two Monitor, investigate, and remediate risky workload identities

The InvoiceSync service principal is confirmed compromised after its client secret was found in a public GitHub repository.

Which two actions should you perform to remediate the workload identity, according to Microsoft guidance? Each correct answer presents part of the solution.

- A. Add a new credential, preferably an X.509 certificate, and remove all existing credentials from the application and the service principal.
- B. Rotate the Azure Key Vault secrets that the service principal can access.
- C. Require MFA for the service principal.
- D. Reset the password of the application owner.
- E. Dismiss the risk in the Risky workload identities report.

Subdominio 4: Implement Global Secure Access

Q39 **Select two** Deploy Global Secure Access clients

Contoso has Microsoft Entra Internet Access licenses and deploys the Global Secure Access client for Windows by using Intune. The Internet Access traffic forwarding profile is enabled for all users.

- Device1: Windows 11, Microsoft Entra joined
- Device2: Windows 10 Enterprise LTSC 2021 (64-bit), Microsoft Entra hybrid joined
- Device3: Personal Windows 11 laptop, Microsoft Entra registered
- Device4: Azure Virtual Desktop multi-session host
- Device5: Windows 365 Cloud PC

On which two devices will Internet Access traffic NOT be tunneled by the client? Each correct answer presents part of the solution.

- A. Device1
- B. Device2
- C. Device3
- D. Device4
- E. Device5

Q40 **Drag/order** Deploy and manage Private Access

Contoso wants to replace its VPN. Remote users must reach on-premises file servers (TCP 445) and Remote Desktop hosts (TCP 3389) through Microsoft Entra Private Access by using Quick Access. The Global Secure Access client is already deployed.

Which four actions should you perform in sequence? (Two actions aren't used.)

- A. Install a Microsoft Entra private network connector on an on-premises server and add it to a connector group.
- B. In Global Secure Access > Applications > Quick Access, enter a name, select the connector group, and add application segments with the FQDNs or IP ranges and ports 445 and 3389.
- C. Assign users or groups directly to the Quick Access enterprise application.
- D. Enable the Private Access traffic forwarding profile.
- E. Enable the Microsoft traffic forwarding profile.
- F. Publish the file servers as Application Proxy apps with an external URL.

Q41 Multiple choice Deploy and manage Private Access

Contoso uses Quick Access for its file servers, with a Conditional Access policy that requires MFA. A new ERP server at 10.20.5.20 (TCP 443) must be reachable only by the Finance group, and access must require a compliant device and MFA. The existing Quick Access policy for file servers must not change.

What should you do?

- A. Add 10.20.5.20:443 to Quick Access and add Require device to be marked as compliant to the Conditional Access policy linked to Quick Access.
- B. Create a Global Secure Access application (per-app access) for 10.20.5.20:443, assign the Finance group, and link a Conditional Access policy that requires a compliant device and MFA to that application.
- C. Create a named location for 10.20.5.20 and a Conditional Access policy that blocks all other locations.
- D. Add the Finance group as a nested member of the group that's assigned to Quick Access.

Q42 Select two Deploy and manage Internet Access

Contoso must block the Gambling web category for members of the Sales group only. The Internet Access traffic forwarding profile is enabled and the Global Secure Access client is deployed. You already created a web content filtering policy with a Block rule for the Gambling category.

Which two additional configurations are required? Each correct answer presents part of the solution.

- A. A security profile that links the web content filtering policy.
- B. A Conditional Access policy for the Sales group that targets All internet resources with Global Secure Access and uses the session control Use Global Secure Access security profile.
- C. Linking the web content filtering policy to the baseline security profile.
- D. Enabling the Microsoft traffic forwarding profile.
- E. A named location for the Sales office.

Case study 2: Fabrikam Logistics (usar para Q43 y Q44)

Fabrikam Logistics has 3,000 employees. All employees have Microsoft Entra ID P1, and 600 remote employees also have Microsoft Entra Suite. Windows devices are Microsoft Entra joined and run the Global Secure Access client. The Seattle warehouse connects to Global Secure Access through a remote network (branch router). The Microsoft traffic forwarding profile is enabled.

Requirements:

- R1: Stolen tokens replayed from outside Fabrikam's Global Secure Access connections must be rejected for Microsoft 365 and other Microsoft Entra integrated apps. Administrators must not maintain lists of egress IP addresses.
- R2: Users on corporate devices must not be able to sign in to any other Microsoft Entra tenant, except the partner tenant contoso.com.
- R3: Sign-in logs must show each user's real public IP address instead of the proxy egress IP address.
- Administrative effort must be minimized.

Q43 Case study (Multiple choice) Deploy and manage Internet Access for Microsoft 365

Refer to Case study 2. Which solution meets R1?

- A. Enable Conditional Access signaling in Global Secure Access (Session management > Adaptive access). Then create a Conditional Access policy for All resources with the Network condition set to include Any location and exclude All Compliant Network locations, and the grant control Block access.
- B. Create a named location that contains the Global Secure Access egress IP addresses, and block all other locations.
- C. Enable source IP restoration and create a location-based Conditional Access policy with the office IP ranges.
- D. Enable universal tenant restrictions.

Q44 Case study (Multiple choice) Deploy and manage Internet Access for Microsoft 365

Refer to Case study 2. Which solution meets R2?

- A. In cross-tenant access settings, configure the default tenant restrictions v2 policy to block external accounts and apps, add contoso.com in Organizational settings with tenant restrictions that allow it, and then turn on universal tenant restrictions in Global Secure Access (Settings > Session management).
- B. Configure the default outbound B2B collaboration settings to block all organizations, and allow only contoso.com.
- C. Configure the default inbound B2B collaboration settings to block all organizations, and allow only contoso.com.
- D. Enable source IP restoration and block sign-ins from IP addresses that aren't Fabrikam's.

5. Respuestas y explicaciones

Lee siempre el "por qué las otras no". El SC-300 se pierde en los distractores, no en la teoría.

Subdominio 1: Plan, implement, and manage Microsoft Entra user authentication

Q1 Yes/No series

Respuesta: 1 = No, 2 = Yes, 3 = Yes

Por qué es correcta:

- 1 No. El Authentication Administrator crea TAP solo para usuarios sin rol de admin (members). Para alguien con rol de admin, como Helpdesk Administrator, hace falta **Privileged Authentication Administrator**. Y ninguno de los dos puede crearse una TAP a sí mismo.
- 2 Yes. Learn lo dice así: puedes crear una TAP para cualquier usuario, pero **solo los usuarios dentro del alcance de la política pueden iniciar sesión con ella**.
- 3 Yes. Con una TAP de un solo uso, registrar un método passwordless tiene que terminar **en 10 minutos**. Ese límite no aplica a una TAP de varios usos.

Por qué las otras no:

- Trampa de la 1: pensar que Authentication Administrator sirve para todos. La escalera es Authentication Admin (members) y Privileged Authentication Admin (members y admins).
- Trampa de la 2: confundir crear la TAP con poder usarla. El alcance de la política decide el uso.
- Trampa de la 3: creer que el lifetime (1 hora) es el límite. Con TAP one-time, el registro se cierra a los 10 minutos.

Fuente: <https://learn.microsoft.com/entra/identity/authentication/howto-authentication-temporary-access-pass#create-a-temporary-access-pass> y <https://learn.microsoft.com/entra/identity/authentication/howto-authentication-temporary-access-pass#limitations>

Q2 Yes/No series

Respuesta: 1 = Yes, 2 = Yes, 3 = No

Por qué es correcta:

- 1 Yes. Si la CA no tiene CRL configurado, **Microsoft Entra ID no revisa revocación** y la autenticación no se bloquea. Por eso el CRL por HTTP es prerequisite.
- 2 Yes. En el ejemplo de Learn, cuando un certificado cumple una regla de issuer (single-factor) y una de policy OID (multifactor), **la regla de policy OID tiene precedencia** y el certificado cuenta como MFA.
- 3 No. PrincipalName es un binding de **low affinity**. Con High a nivel tenant, Entra quita los bindings low de la lista y solo evalúa SKI, SHA1PublicKey o IssuerAndSerialNumber contra certificateUserIds. Learn avisa que puedes dejar fuera a todo el tenant.

Por qué las otras no:

- Trampa de la 1: pensar que "revocado en la CA" bloquea solo. Sin CRL URL en Entra, no hay chequeo.
- Trampa de la 2: creer que gana la regla más general (issuer). Gana la de policy OID.
- Trampa de la 3: confundir affinity (qué tan único es el mapeo) con protection level (single-factor o MFA). Son dos perillas distintas.

Fuente: <https://learn.microsoft.com/entra/identity/authentication/how-to-certificate-based-authentication#prerequisites>, <https://learn.microsoft.com/entra/identity/authentication/how-to-certificate-based-authentication#test-custom-authentication-binding-rules> y <https://learn.microsoft.com/entra/identity/authentication/concept-certificate-based-authentication-technical-deep-dive#username-binding-policy>

Q3 Multiple choice

Respuesta: B

Por qué es correcta: Los **passkey profiles** existen justo para esto: reglas distintas por grupo (tipo de passkey, attestation y AAGUIDs). Un perfil estricto para admins y otro flexible para HR. Recuerda: hasta **3 perfiles** incluyendo el Default, y después de hacer opt-in ya no puedes regresar.

Por qué las otras no:

- A. **Los synced passkeys no soportan attestation.** Con attestation obligatoria y una allow list de dos llaves, HR no puede registrar iCloud Keychain ni Google Password Manager.
- C. Authenticator en modo Passwordless es phone sign-in, no un synced passkey. No cumple el requisito de HR.
- D. Una authentication strength controla el sign-in, no el registro, y la built-in acepta cualquier llave FIDO2. No verifica marca y modelo al registrar.

Fuente: <https://learn.microsoft.com/entra/identity/authentication/how-to-authentication-passkeys-fido2#passkey-profiles> y <https://learn.microsoft.com/entra/identity/authentication/how-to-authentication-passkeys-fido2#synced-passkeys-fido2>

Q4 Multiple choice

Respuesta: B

Por qué es correcta: Un passkey en Authenticator es una credencial **FIDO2 device-bound**. Por eso se controla en la política **Passkey (FIDO2)**, con key restrictions por AAGUID (Authenticator for iOS y for Android). Learn trae este mismo patrón para un rollout piloto: un perfil que bloquea los AAGUIDs de Authenticator para todos y otro que los permite para los grupos piloto. Si un usuario está en varios perfiles, basta con que el passkey cumpla uno.

Por qué las otras no:

- A. El modo Passwordless de la política de Authenticator es **passwordless phone sign-in** (notificación con número), no un passkey. Es la confusión clásica.
- C. La campaign solo empuja a registrar algo. No habilita passkeys en Authenticator ni impide que otros los registren.
- D. Una authentication strength no habilita ningún método. Y Passwordless MFA también acepta phone sign-in.

Fuente: <https://learn.microsoft.com/entra/identity/authentication/how-to-enable-authenticator-passkey#configure-a-profile-for-passkeys-in-authenticator> y

<https://learn.microsoft.com/entra/identity/authentication/how-to-authentication-passkeys-fido2#passkey-profiles>

Q5 Multiple choice

Respuesta: C

Por qué es correcta: Desde el **30 de enero de 2021** los lifetimes de refresh token y session token ya no se configuran con token lifetime policies. Learn dice que para controlar cada cuánto se vuelve a iniciar sesión se usa **Conditional Access sign-in frequency**.

Por qué las otras no:

- A. MaxAgeMultiFactor es una propiedad retirada. Si existe en una política, **se ignora**.
- B. AccessTokenLifetime (de 10 minutos a 1 día) cambia access, ID y SAML tokens. Cuando el access token vence, el cliente usa el refresh token en silencio y el usuario no vuelve a escribir nada.
- D. Remember MFA es una configuración legacy en días, reduce prompts en vez de forzarlos y Learn pide apagarla antes de usar sign-in frequency.

Dato extra para el examen: access token por default de 60 a 90 minutos, refresh token de 90 días (24 horas para SPA). Y ojo: el outline dice OAuth, pero el método de MFA se llama **OATH tokens (TOTP)**.

Fuente: <https://learn.microsoft.com/entra/identity-platform/configurable-token-lifetimes#token-lifetime-policies-for-refresh-tokens-and-session-tokens-retired> y

<https://learn.microsoft.com/entra/identity/conditional-access/concept-session-lifetime#user-sign-in-frequency>

Q6 Yes/No series

Respuesta: 1 = Yes, 2 = No, 3 = No

Por qué es correcta:

- 1 Yes. Report suspicious activity está integrado con ID Protection y **pone al usuario en High User Risk** (no pasa si el usuario hizo passwordless).
- 2 No. Las políticas basadas en riesgo **piden Entra ID P2**. Con P1 usas las risk detections para actuar a mano o automatizas con Microsoft Graph.
- 3 No. En MFA de nube, trusted IPs **solo acepta rangos públicos**. Rangos privados solo con MFA Server. Learn recomienda named locations de CA en lugar de trusted IPs.

Por qué las otras no:

- Trampa de la 1: buscar "Fraud alert". Ya no existe: Report suspicious activity lo reemplazó el 1 de marzo de 2025.
- Trampa de la 2: asumir que ver el riesgo es lo mismo que automatizar con él. Automatizar es P2.
- Trampa de la 3: pensar en la IP que ve el usuario en su tarjeta de red. Entra ve la IP pública de salida.

Fuente: <https://learn.microsoft.com/entra/identity/authentication/howto-mfa-mfasettings#report-suspicious-activity> y <https://learn.microsoft.com/entra/identity/authentication/howto-mfa-mfasettings#trusted-ips>

Q7 Select two

Respuesta: A y B

Por qué es correcta: Si el password se administra on-prem (PHS, PTA o federación) y **no hay writeback**, SSPR le dice al usuario que contacte a su admin. El writeback se prende **en los dos lados**: en el wizard de Connect (Optional features) y en Password reset > On-premises integration (rol mínimo Hybrid Identity Administrator). Además, la cuenta de Connect necesita permisos en AD: Reset password, Change password, escribir lockoutTime y pwdLastSet, y Unexpire Password.

Por qué las otras no:

- C. Learn dice que SSPR con writeback **no está garantizado** cuando staged rollout está activo para un grupo. Empeora el escenario.
- D. Seamless SSO es para iniciar sesión sin escribir password en la red corporativa. No tiene nada que ver con reset.
- E. El número de métodos no es la causa del mensaje.

Fuente: <https://learn.microsoft.com/entra/identity/authentication/concept-sspr-howitworks#how-does-the-password-reset-process-work>, <https://learn.microsoft.com/entra/identity/authentication/tutorial-enable-sspr-writeback#enable-password-writeback-in-microsoft-entra-connect> y <https://learn.microsoft.com/entra/identity/authentication/tutorial-enable-sspr-writeback#enable-password-writeback-for-sspr>

Q8 Multiple choice

Respuesta: B

Por qué es correcta: Las cuentas con rol de administrador (Helpdesk Administrator está en la lista) tienen SSPR habilitado por default con una **política two-gate**: dos métodos, **sin security questions**, y no se puede cambiar. Por eso Learn recomienda **probar SSPR con un usuario sin rol de admin**.

Por qué las otras no:

- A. Al revés: SSPR para admins está habilitado por default. Se puede apagar con AllowedToUseSspr en false.
- C. SSPR sí soporta nested groups, y Megan ya es miembro directo. Ojo con el dato real: en el portal solo puedes elegir **un grupo** en Selected.
- D. Al revés: security questions hoy **solo se habilitan en la política legacy** de SSPR.

Fuente: <https://learn.microsoft.com/entra/identity/authentication/concept-sspr-policy#administrator-reset-policy-differences> y <https://learn.microsoft.com/entra/identity/authentication/tutorial-enable-sspr#enable-self-service-password-reset>

Q9 Drag/order

Respuesta: B, C, D (en ese orden)

Por qué es correcta: **Cloud Kerberos trust** es el modelo recomendado y **el único híbrido que no pide PKI**. Los pasos de Learn son: desplegar Microsoft Entra Kerberos (crea el objeto AzureADKerberos, que se ve como un RODC), configurar las dos políticas y enrolar. En hybrid joined, el primer sign-in con la credencial nueva necesita **línea de vista a un DC**.

Por qué las otras no:

- A. Eso es certificate trust: pide PKI y AD FS como registration authority, y no soporta PHS ni PTA. Rompe el requisito.
- E. Si "Use certificate for on-premises authentication" está activo, **certificate trust le gana** a cloud Kerberos trust. Debe quedar sin configurar.
- Orden: sin el objeto Kerberos, el chequeo de prerrequisitos de provisioning en hybrid joined falla (no hay partial TGT).

Fuente: <https://learn.microsoft.com/windows/security/identity-protection/hello-for-business/deploy/hybrid-cloud-kerberos-trust#deploy-microsoft-entra-kerberos>, <https://learn.microsoft.com/windows/security/identity-protection/hello-for-business/deploy/hybrid-cloud-kerberos-trust#configure-windows-hello-for-business-policy-settings> y <https://learn.microsoft.com/windows/security/identity-protection/hello-for-business/deploy/#pki-requirements>

Q10 Drag/order

Respuesta: A, B, C, D (en ese orden)

Por qué es correcta: Es el flujo de Learn para híbrido: primero on-prem (deshabilitar y **resetear el password dos veces** para mitigar pass-the-hash), después Entra (revocar refresh tokens) y al final deshabilitar los devices del usuario. Como la cuenta es sincronizada, el estado disabled llega a Entra con la sync; por eso también revocas sesiones.

Por qué las otras no:

- E. Borrar al usuario no es un paso del procedimiento. Además, en un usuario sincronizado el origen de verdad es AD.
- F. Pedir re-registro de MFA no corta los tokens ya emitidos.
- Dato clave: después de revocar, las apps con **access token** siguen funcionando hasta que el token expira (alrededor de 1 hora). Solo las **apps con CAE** cortan casi en tiempo real.

Fuente: <https://learn.microsoft.com/entra/identity/users/users-revoke-access#revoke-access-for-a-user-in-the-hybrid-environment> y <https://learn.microsoft.com/entra/identity/users/users-revoke-access#when-access-is-revoked>

Q11 Yes/No series

Respuesta: 1 = No, 2 = Yes, 3 = No

Por qué es correcta:

- 1 No. En **modo Audit** los passwords malos solo generan eventos en el log, pero **se aceptan**. Solo Enforced rechaza.
- 2 Yes. La política se aplica **solo donde está instalado el DC agent**. Learn dice que el deployment parcial no es seguro y solo sirve para pruebas.
- 3 No. Principio de diseño: **los DCs nunca hablan directo con internet**. El DC agent pide la política al proxy, y el proxy la pide a Entra.

Por qué las otras no:

- Trampa de la 1: olvidar el modo. En la vida real primero se corre en Audit y luego se pasa a Enforced.
- Trampa de la 2: creer que con un DC agent ya queda protegido todo el dominio. El cliente elige cualquier DC.
- Trampa de la 3: pensar que el DC necesita salida a internet. Solo el proxy la necesita.

Datos rápidos: custom list de hasta **1000 términos** de 4 a 16 caracteres; el DC agent revisa la política cada hora; si no hay política local, el password se acepta y se registra un evento.

Fuente: <https://learn.microsoft.com/entra/identity/authentication/howto-password-ban-bad-on-premises-operations#modes-of-operation>, <https://learn.microsoft.com/entra/identity/authentication/concept-password-ban-bad-on-premises#design-principles> y <https://learn.microsoft.com/entra/identity/authentication/concept-password-ban-bad-on-premises#incremental-deployment>

Q12 Multiple choice

Respuesta: A

Por qué es correcta: Learn lo marca como limitación: **Microsoft Entra Kerberos para Azure Files no soporta MFA**. Las políticas de CA que exigen MFA tienen que **excluir la app del storage account**, o la autenticación falla.

Por qué las otras no:

- B. Un storage account acepta **un solo identity source** a la vez (Entra Kerberos, AD DS o Entra Domain Services).
- C. Ese tag es para identidades cloud-only y el límite de 1010 group SIDs. Aquí los usuarios son híbridos y el problema empezó con la política de MFA.
- D. El realm mapping es para convivir con storage accounts que usan AD DS. No arregla un bloqueo de CA.

Fuente: <https://learn.microsoft.com/entra/identity/authentication/kerberos#mfa-incompatibility-for-azure-files-authentication> y <https://learn.microsoft.com/azure/storage/files/storage-files-identity-auth-hybrid-identities-enable#prerequisites>

Subdominio 2: Plan, implement, and manage Microsoft Entra Conditional Access

Q13 Multiple choice

Respuesta: B

Por qué es correcta: Security defaults y CA **no se combinan**. Learn dice que las organizaciones que implementan CA para reemplazar security defaults **deben deshabilitarlos**. El rol mínimo para tocar security defaults es **Conditional Access Administrator**. Al deshabilitarlos, Microsoft ofrece Microsoft-managed policies para no perder la protección base.

Por qué las otras no:

- A. No hay apagado automático. Es un paso explícito en Properties > Manage security defaults.
- C. Per-user MFA es legacy y no permite condiciones por app ni por ubicación.
- D. Trusted IPs es de la configuración legacy de MFA, no de CA, y no resuelve la exclusión de la cuenta de servicio.

Fuente: <https://learn.microsoft.com/entra/fundamentals/security-defaults#disabling-security-defaults> y <https://learn.microsoft.com/entra/fundamentals/security-defaults#move-from-security-defaults-to-conditional-access>

Q14 Multiple choice

Respuesta: B

Por qué es correcta: Regla de oro de Learn: **si ninguna política dispara un control, el access token se emite por default**. CA01 solo pone MFA a Finance; no bloquea a nadie más. Para "solo Finance entra" hace falta una **segunda política de block** que incluya a todos y excluya a Finance (y a break-glass).

Por qué las otras no:

- A. Todos entrarían con MFA. No es "solo Finance".
- C. AND u OR entre controles no cambia a quién aplica la política.
- D. Report-only no aplica controles. Además, al incluir All users sin excluir a Finance, si la pasas a On bloqueas a Finance.

Fuente: <https://learn.microsoft.com/entra/identity/conditional-access/plan-conditional-access#combining-policies>

Q15 Multiple choice

Respuesta: A

Por qué es correcta: En Guest or external users puedes elegir **el tipo de usuario externo** (B2B collaboration guest, B2B collaboration member, B2B direct connect, local guest, service provider, other) y **uno o varios tenants** específicos. Así la política pega solo a Fabrikam.

Por qué las otras no:

- B. Guest Inviter es un rol para invitar, no representa a los guests.
- C. El grupo dinámico incluye a los guests de Tailspin también.
- D. Deja fuera a todos los guests, incluido Fabrikam.

Trampa extra de assignments: en Directory roles, CA **solo soporta roles built-in**. No aplica a roles con scope de administrative unit ni a custom roles.

Fuente: <https://learn.microsoft.com/entra/identity/conditional-access/concept-conditional-access-users-groups#include-users>

Q16 Select two

Respuesta: A y B

Por qué es correcta: La strength built-in **Phishing-resistant MFA** acepta FIDO2 security key, Windows Hello for Business o platform credential, y **CBA multifactor**. Son métodos que necesitan interacción entre el método y la superficie de sign-in.

Por qué las otras no:

- C. Authenticator phone sign-in cumple **Passwordless MFA**, pero no phishing-resistant.
- D. TAP (one-time o multi-use) solo cumple la **strength MFA**.
- E. Password más algo que tienes solo cumple la **strength MFA**.

Reglas extra: las 3 strengths built-in no se editan; no puedes usar **Require multifactor authentication** y **Require authentication strength** en la misma política; y la strength no limita la autenticación inicial (el usuario puede escribir su password y luego se le pide el método fuerte).

Fuente: <https://learn.microsoft.com/entra/identity/authentication/concept-authentication-strengths#built-in-authentication-strengths> y <https://learn.microsoft.com/entra/identity/authentication/concept-authentication-strengths#limitations>

Q17 Multiple choice

Respuesta: B

Por qué es correcta: Con **app enforced restrictions**, Entra le pasa a la app la información del device (compliant o domain-joined) y la app decide: **experiencia limitada** en device no administrado y completa en device administrado. Funciona con SharePoint y Exchange. Hasta existe un template: "Use application enforced restrictions for unmanaged devices".

Por qué las otras no:

- A. Require compliant **bloquea el device no administrado**. No da acceso limitado.
- C. Funciona, pero necesita Defender for Cloud Apps. El requisito prohíbe productos extra.
- D. Bloquea en lugar de limitar.

Fuente: <https://learn.microsoft.com/entra/identity/conditional-access/concept-conditional-access-session#application-enforced-restrictions> y <https://learn.microsoft.com/entra/identity/conditional-access/concept-conditional-access-policy-common#template-categories>

Q18 Multiple choice

Respuesta: B

Por qué es correcta: Es el escenario de Learn: **excluir los devices que cumplen el filtro y bloquear todo lo demás**. En un device no registrado todas las propiedades son null, así que la regla con operador positivo (Equals) no lo excluye y **queda bloqueado**. Los PAW sí se excluyen porque son Intune managed y compliant (requisito para leer extensionAttributes).

Por qué las otras no:

- A. Bloquearía justo a los PAW.
- C. Con operador positivo el filtro **no aplica** a devices no registrados, y pedir MFA no restringe a PAW.
- D. Microsoft Admin Portals no es Azure Resource Manager, y hybrid joined no significa PAW.

Fuente: <https://learn.microsoft.com/entra/identity/conditional-access/concept-condition-filters-for-devices#common-scenarios> y <https://learn.microsoft.com/entra/identity/conditional-access/concept-condition-filters-for-devices#policy-behavior-with-filter-for-devices>

Q19 Yes/No series

Respuesta: 1 = No, 2 = No, 3 = Yes

Por qué es correcta:

- 1 No. What If **solo incluye políticas On o en report-only**.
- 2 No. Learn lo dice directo: What If **no prueba service dependencies**. Si simulas Teams, no ves la política de Exchange Online.
- 3 Yes. La lista de políticas que no aplican trae la razón: **la primera condición que no se cumplió**.

Por qué las otras no:

- Trampa de la 1: usar What If para "probar" una política apagada. Primero pásala a report-only.
- Trampa de la 2: pensar que What If entiende las dependencias de Teams. No las entiende; para eso target al grupo Office 365.
- Dato extra: en el What If nuevo (basado en API), grupos de apps como Office 365 no hacen match; se da el App ID.

Fuente: <https://learn.microsoft.com/entra/identity/conditional-access/what-if-tool#how-it-works> y <https://learn.microsoft.com/entra/identity/conditional-access/what-if-tool#evaluation>

Q20 Multiple choice

Respuesta: B

Por qué es correcta: Report-only no soporta políticas con User Actions (Register security information o Register or join devices). What If sí te deja elegir una user action como target y simular para un usuario sin molestar a nadie.

Por qué las otras no:

- A. Report-only no está disponible para user actions.
- C. El workbook muestra resultados de políticas en report-only o activas. No tienes esos datos para esta política.
- D. Policy impact también se alimenta de sign-ins reales de políticas activas o en report-only.

Detalle de configuración: si usas la user action Register or join devices, pon en No el device setting "Require Multifactor Authentication to register or join devices", o la política no se aplica bien.

Fuente: <https://learn.microsoft.com/entra/identity/conditional-access/concept-conditional-access-report-only#overview>, <https://learn.microsoft.com/entra/identity/conditional-access/what-if-tool#how-it-works> y <https://learn.microsoft.com/entra/identity/conditional-access/concept-conditional-access-cloud-apps#user-actions>

Q21 Select two

Respuesta: A y B

Por qué es correcta: Persistent browser session es el control que decide si la sesión sobrevive al cerrar el navegador. Learn dice que **exige "All cloud apps"** (hoy All resources), porque todas las pestañas comparten el mismo session token.

Por qué las otras no:

- C. Con Office 365 solamente, el control no funciona como se espera.
- D. Every time pide reautenticación cuando la sesión se evalúa, no controla la persistencia. Learn pide usarlo poco para no causar fatiga de MFA.
- E. Branding es para todo el tenant, no distingue devices. Y si existen los dos, la política de CA le gana al "Stay signed in?".

Fuente: <https://learn.microsoft.com/entra/identity/conditional-access/howto-conditional-access-session-lifetime#policy-2-persistent-browser-session> y <https://learn.microsoft.com/entra/identity/conditional-access/concept-session-lifetime#persistence-of-browsing-sessions>

Q22 Yes/No series

Respuesta: 1 = Yes, 2 = No, 3 = No

Por qué es correcta:

- 1 Yes. Deshabilitar o borrar la cuenta es un **evento crítico** de CAE. Exchange, SharePoint y Teams lo reciben casi en tiempo real (puede haber hasta 15 minutos de latencia).
- 2 No. CAE **solo entiende IP named locations**. Con country o region, o con MFA trusted IPs, Entra emite un token de una hora sin chequeo instantáneo de IP.
- 3 No. Cambios de **grupo o de política pueden tardar hasta un día** en los resource providers. Para aplicarlos ya, revoca las sesiones del usuario.

Por qué las otras no:

- Trampa de la 1: pensar que el access token siempre vive su hora completa. Con CAE no.
- Trampa de la 2: asumir que cualquier location sirve. Para enforcement instantáneo: IP ranges, IPv4 e IPv6.
- Trampa de la 3: meter "cambio de grupo" en la lista de eventos críticos. La lista es: cuenta deshabilitada o borrada, password cambiado o reseteado, MFA habilitado, revoke de refresh tokens y high user risk.

Fuente: <https://learn.microsoft.com/entra/identity/conditional-access/concept-continuous-access-evaluation#critical-event-evaluation>, <https://learn.microsoft.com/entra/identity/conditional-access/concept-continuous-access-evaluation#supported-location-policies> y <https://learn.microsoft.com/entra/identity/conditional-access/concept-continuous-access-evaluation#group-membership-and-policy-update-effective-time>

Q23 Drag/order

Respuesta: A, B, C, D (en ese orden)

Por qué es correcta: Es el orden de la guía de SharePoint: **crear el authentication context (con Publish to apps), crear la política que lo usa como target, ligar el context a la etiqueta y aplicar la etiqueta al sitio**. La alternativa sin etiqueta es Set-SPOSite con -ConditionalAccessPolicy AuthenticationContext (pide Microsoft 365 E5 o SharePoint Advanced Management).

Por qué las otras no:

- E. CA no puede apuntar a la URL de un sitio. Para granularidad dentro de una app existe el authentication context.
- F. La ubicación no es parte del requisito.
- Orden: si no marcas **Publish to apps**, el context no aparece para Purview ni para las apps. Hasta 99 contexts (c1 a c99). Las apps que no soportan authentication context reciben acceso denegado.

Fuente: <https://learn.microsoft.com/sharepoint/authentication-context-example#set-up-an-authentication-context> y <https://learn.microsoft.com/entra/identity/conditional-access/concept-conditional-access-cloud-apps#configure-authentication-contexts>

Q24 Multiple choice

Respuesta: B

Por qué es correcta: PIM puede pedir un **authentication context** al activar. La política de CA que usa ese context define los requisitos (strength phishing-resistant y compliant device). Learn recomienda **crear y encender la política antes** de configurar el context en PIM.

Por qué las otras no:

- A. Solo pide MFA, y puede no pedir nada si el usuario ya hizo MFA en la sesión. No cubre phishing-resistant ni device.
- C. Learn dice que **no combines** el authentication context con el directory role en la misma política: durante la activación el usuario **todavía no tiene el rol**, así que la política no aplica.
- D. Protected actions protege permisos como administrar CA, named locations o cross-tenant settings. No es el mecanismo para activar roles en PIM.

Fuente: <https://learn.microsoft.com/entra/id-governance/privileged-identity-management/pim-how-to-change-default-settings#on-activation-require-microsoft-entra-conditional-access-authentication-context>

Q25 Yes/No series

Respuesta: 1 = Yes, 2 = No, 3 = No

Por qué es correcta:

- 1 Yes. Para agregar o quitar protected actions se necesita **Conditional Access Administrator o Security Administrator**, más licencia P1.
- 2 No. La política que usa el context **tiene que estar On**. Si está en Off o Report-only, Learn documenta el síntoma "Policy is never satisfied": el admin entra en un ciclo de reautenticación. Para salir existe <https://aka.ms/MSALProtectedActions>.
- 3 No. **Azure PowerShell no soporta step-up** para protected actions y falla. Microsoft Graph PowerShell y Graph Explorer sí.

Por qué las otras no:

- Trampa de la 1: creer que solo Global Admin o Privileged Role Admin lo configuran.
- Trampa de la 2: tratar report-only como "casi On". Para protected actions no sirve.
- Trampa de la 3: confundir Azure PowerShell (ARM) con Microsoft Graph PowerShell.

Fuente: <https://learn.microsoft.com/entra/identity/role-based-access-control/protected-actions-add#step-2-add-protected-actions>, <https://learn.microsoft.com/entra/identity/role-based-access-control/protected-actions-add#symptom---policy-is-never-satisfied> y <https://learn.microsoft.com/entra/identity/role-based-access-control/protected-actions-overview#what-happens-with-protected-actions-and-applications>

Q26 Multiple choice

Respuesta: B

Por qué es correcta: Learn es explícito: las políticas creadas desde template **solo excluyen al usuario que las crea**. Las demás exclusiones (break-glass) se agregan editando la política después.

Por qué las otras no:

- A. No hay exclusión automática de break-glass.
- C. Los templates crean la política **en Report-only por default**, no en Off.
- D. Las políticas de template se editan como cualquier otra. Exportar e importar JSON existe, pero no es necesario.

Fuente: <https://learn.microsoft.com/entra/identity/conditional-access/concept-conditional-access-policy-common#template-categories> y <https://learn.microsoft.com/entra/identity/conditional-access/concept-conditional-access-policy-common#user-exclusions>

Q27 Case study (Multiple choice)

Respuesta: A

Por qué es correcta: **Protected actions** aplica CA **en el momento de la acción y sin importar el rol** que da el permiso. La lista de permisos soportados incluye CA policies y named locations. La strength custom con AAGUIDs asegura que sea una llave FIDO2; la built-in Phishing-resistant también aceptaría WHfB o CBA.

Por qué las otras no:

- B. Depende del rol (Security Admin o Global Admin también pueden editar CA) y se evalúa al sign-in, no al cambio.
- C. Solo pide MFA al activar, y no aplica a otros roles con el mismo permiso.
- D. Quitar permisos no es pedir una llave FIDO2 al hacer el cambio. Learn además dice que protected actions no se usa para bloquear por identidad.

Fuente: <https://learn.microsoft.com/entra/identity/role-based-access-control/protected-actions-overview#what-permissions-can-be-used-with-protected-actions> y <https://learn.microsoft.com/entra/identity/authentication/concept-authentication-strength-advanced-options#configure-advanced-options-for-passkeys-fido2>

Q28 Case study (Multiple choice)

Respuesta: C

Por qué es correcta: Forzar el cambio de password automáticamente cuando hay riesgo es una **política de user risk**, y las políticas basadas en riesgo **piden Microsoft Entra ID P2**. La detección de leaked credentials sí llega con P1, pero automatizar la respuesta con CA no.

Por qué las otras no:

- A. Protected actions pide P1. Adatum lo tiene.
- B. Authentication context con CA es P1, y la sensitivity label de sitios la cubre el add-on E5 Compliance.
- D. App enforced restrictions es un session control de CA (P1).

Fuente: <https://learn.microsoft.com/entra/id-protection/concept-identity-protection-policies> y <https://learn.microsoft.com/entra/identity/conditional-access/plan-conditional-access#prerequisites>

Subdominio 3: Manage risk by using Microsoft Entra ID Protection

Q29 Multiple choice

Respuesta: B

Por qué es correcta: **Require risk remediation** se adapta al método del usuario: con password pide un **secure password change**; en passwordless **revoca las sesiones** y pide sign-in otra vez. Al elegirlo se agregan solos **Require authentication strength** y **Sign-in frequency Every time**. Las políticas legacy de ID Protection se retiran el **1 de octubre de 2026**.

Por qué las otras no:

- A. La política legacy se retira y no ofrece este control.
- C. MFA remedia **sign-in risk**, no user risk.
- D. Learn pide **no combinar** user risk y sign-in risk en la misma política. Y password change no sirve para usuarios passwordless.

Fuente: <https://learn.microsoft.com/entra/id-protection/concept-identity-protection-policies#require-risk-remediation-control> y <https://learn.microsoft.com/entra/id-protection/howto-identity-protection-configure-risk-policies#migrate-risk-policies-to-conditional-access>

Q30 Yes/No series

Respuesta: 1 = Yes, 2 = Yes, 3 = No

Por qué es correcta:

- 1 Yes. Learn: el usuario **debe tener un método registrado** que satisfaga MFA antes de caer en la política. Si no puede cumplir el control, queda bloqueado y necesita al admin.
- 2 Yes. Al pasar MFA, el estado cambia de **"At risk" a "Remediated"** con el detalle "User passed multifactor authentication".
- 3 No. **Nunca combines sign-in risk y user risk** en la misma política. Crea una para cada uno.

Por qué las otras no:

- Trampa de la 1: pensar que el usuario se registra ahí mismo. Por eso existe la MFA registration policy o la registration campaign antes de activar riesgo.
- Trampa de la 3: querer "ahorrar" políticas. Las condiciones se suman con AND y el remedio de cada riesgo es distinto.

Fuente: <https://learn.microsoft.com/entra/id-protection/concept-identity-protection-policies#sign-in-risk-based-conditional-access-policy>, <https://learn.microsoft.com/entra/id-protection/howto-identity-protection-remediate-unblock#self-remediation-of-sign-in-risk> y <https://learn.microsoft.com/entra/id-protection/howto-identity-protection-configure-risk-policies>

Q31 Multiple choice

Respuesta: B

Por qué es correcta: Con **PHS habilitado**, el setting **"Allow on-premises password change to reset user risk"** hace que un cambio de password on-prem remedie el user risk automáticamente. Es opt-in y lo configura como mínimo un Security Operator.

Por qué las otras no:

- A. Writeback va de la nube hacia AD. No hace que un cambio hecho en AD cuente como remedio.
- C. Un reset por SSPR en la nube sí remedia, pero estos usuarios cambian el password on-prem.
- D. Dismiss no cambia el password y deja la identidad igual de expuesta.

Fuente: <https://learn.microsoft.com/entra/id-protection/howto-identity-protection-remediate-unblock#allow-on-premises-password-reset-to-remediate-user-risks>

Q32 Multiple choice

Respuesta: B

Por qué es correcta: Prerrequisito de la campaña de Authenticator: los usuarios deben estar habilitados para Authenticator con **Authentication mode Any o Push**. Con **Passwordless no son elegibles** para el nudge.

Por qué las otras no:

- A. El snooze no arregla la elegibilidad.
- C. En Microsoft managed también se exige estar habilitado para Authenticator push.
- D. La MFA registration policy pide registrar MFA a quien no tiene nada. Estos usuarios ya tienen SMS.

Datos de la campaña: se configura como mínimo con Authentication Policy Administrator; snooze de 0 a 14 días; con snoozes limitados, después de 3 el registro es obligatorio; no hay nudge dentro de una sesión SSO.

Fuente: <https://learn.microsoft.com/entra/identity/authentication/how-to-mfa-registration-campaign#prerequisites> y <https://learn.microsoft.com/entra/identity/authentication/how-to-mfa-registration-campaign#choose-a-campaign-state>

Q33 Yes/No series

Respuesta: 1 = Yes, 2 = No, 3 = Yes

Por qué es correcta:

- 1 Yes. La política pide registro en el siguiente sign-in interactivo y da **14 días**. Después ya no se puede saltar.
- 2 No. La campaña apunta a **un método a la vez**: Authenticator o passkey, no los dos.
- 3 Yes. Con snoozes limitados, el usuario puede posponer **3 veces**; luego el registro es obligatorio.

Por qué las otras no:

- Trampa de la 1: confundir los 14 días de la MFA registration policy con el período de gracia de security defaults, que ya no existe desde julio de 2024.
- Trampa de la 2: la campaña nueva soporta passkeys, pero no en paralelo con Authenticator.
- Trampa de la 3: creer que se puede esconder el botón de snooze. No se puede; se limita a 3.

Fuente: <https://learn.microsoft.com/entra/id-protection/howto-identity-protection-configure-mfa-policy#user-experience>, <https://learn.microsoft.com/entra/identity/authentication/how-to-mfa-registration-campaign#snooze-experience> y <https://learn.microsoft.com/entra/identity/authentication/how-to-mfa-registration-campaign#can-i-run-registration-campaigns-for-both-authenticator-and-passkeys-at-the-same-time>

Q34 Select two

Respuesta: B y C

Por qué es correcta: Learn lo pone en los prerequisites: **Security Operator** es el rol mínimo para **descartar user risk**, y **User Administrator** es el mínimo para **resetear passwords**. Para generar el password temporal desde ID Protection necesitas **los dos**: uno abre ID Protection y el otro permite el reset.

Por qué las otras no:

- A. Security Reader solo lee.
- D. Security Administrator sirve para crear o editar políticas de riesgo, pero no resetea passwords y da más de lo necesario.
- E. Global Reader es el mínimo para ver los reportes de riesgo, no para actuar.

Fuente: <https://learn.microsoft.com/entra/id-protection/howto-identity-protection-remediate-unblock#prerequisites> y <https://learn.microsoft.com/entra/id-protection/howto-identity-protection-remediate-unblock#generate-a-temporary-password>

Q35 Multiple choice

Respuesta: B

Por qué es correcta: La guía de investigación de Learn para atypical travel dice: si el rango de IP es de una VPN autorizada, **confirma el sign-in como safe** y **agrega el rango de la VPN a named locations** en Entra y en Defender for Cloud Apps. Eso reduce falsos positivos futuros.

Por qué las otras no:

- A. No hay evidencia de compromiso. Confirmar compromised sube el riesgo sin razón.
- C. Excluir usuarios de la política debilita la protección y no arregla la causa (la VPN).
- D. No hay un switch documentado para apagar una detección. La vía es named locations y dar feedback (safe o compromised).

Fuente: <https://learn.microsoft.com/entra/id-protection/howto-identity-protection-investigate-risk#atypical-travel-detections> y <https://learn.microsoft.com/entra/id-protection/howto-identity-protection-investigate-risk#mitigate-future-risks>

Q36 Multiple choice

Respuesta: B

Por qué es correcta: Leaked credentials es una **detección nonpremium** (se ve completa con Free o P1) y **siempre es High**. Learn dice que **un reset de password en la nube remedia** el riesgo de esta detección, incluso para passwords on-prem, siempre que haya **PHS habilitado**. Con un password temporal el estado pasa a Remediated.

Por qué las otras no:

- A. Dismiss deja el estado en Dismissed, pero el password filtrado sigue siendo válido.
- C. MFA remedia sign-in risk, no un password filtrado.
- D. Revocar sesiones corta tokens, pero no cambia el password.

Fuente: <https://learn.microsoft.com/entra/id-protection/concept-identity-protection-risks#leaked-credentials> y <https://learn.microsoft.com/entra/id-protection/howto-identity-protection-remediate-unblock#generate-a-temporary-password>

Q37 Multiple choice

Respuesta: B

Por qué es correcta: Las detecciones de riesgo de workload identities llegan a todos (con detalle limitado sin licencia), pero **el control de acceso basado en riesgo pide Workload Identities Premium**. Y CA para workload identities solo aplica a **service principals single-tenant** registrados en tu tenant.

Por qué las otras no:

- A. P2 cubre usuarios, no workload identities.
- C. Una workload identity **no puede hacer MFA**. El control soportado es Block.
- D. El riesgo del dueño no es el riesgo del service principal.

Recuerda: **managed identities no están en scope** ni para las detecciones ni para CA, y tampoco las apps SaaS multitenant.

Fuente: <https://learn.microsoft.com/entra/id-protection/concept-workload-identity-risk#prerequisites> y <https://learn.microsoft.com/entra/id-protection/concept-workload-identity-risk#enforce-access-controls-with-risk-based-conditional-access>

Q38 Select two

Respuesta: A y B

Por qué es correcta: Los pasos de remediación de Learn son: **inventariar credenciales**, **agregar una nueva** (se recomiendan certificados X.509), **quitar las comprometidas** (si crees que la cuenta está en riesgo, quita todas) y **rotar los secretos de Key Vault** a los que el service principal tiene acceso.

Por qué las otras no:

- C. Las workload identities no pueden hacer MFA.
- D. El dueño no es la credencial filtrada.
- E. Dismiss no invalida el secreto filtrado. Si quieres cortar ya los sign-ins, existe "Disable service principal".

Fuente: <https://learn.microsoft.com/entra/id-protection/concept-workload-identity-risk#remediate-risky-workload-identities>

Subdominio 4: Implement Global Secure Access

Q39 Select two

Respuesta: C y D

Por qué es correcta: Según los prerequisites del cliente para Windows: en devices **Microsoft Entra registered solo se soporta Private Access** (preview), y **Azure Virtual Desktop multi-session no está soportado**.

Por qué las otras no:

- A. Entra joined con Windows 11 es el caso base.
- B. Windows 10 LTSC 2021 o posterior de 64 bits está soportado, y hybrid joined también.
- E. Windows 365 está soportado (igual que AVD single-session).

Datos extra: instalar pide admin local; se puede instalar silencioso con /quiet o como Win32 app en Intune; Internet Access no soporta QUIC ni DNS over HTTPS, así que hay que deshabilitarlos en los navegadores; con RestrictNonPrivilegedUsers el usuario no puede apagar el cliente.

Fuente: <https://learn.microsoft.com/entra/global-secure-access/how-to-install-windows-client#prerequisites>

Q40 Drag/order

Respuesta: A, B, C, D (en ese orden)

Por qué es correcta: Es el resumen de Learn: **connector group con al menos un conector activo**, configurar **Quick Access** (crea una enterprise app nueva), **asignar usuarios y grupos**, ligar CA (opcional aquí) y **habilitar el Private Access profile**. Roles: Global Secure Access Administrator y Application Administrator.

Por qué las otras no:

- E. El Microsoft profile es para tráfico de Microsoft 365, no para recursos privados.
- F. Application Proxy publica apps web con URL externa. Private Access cubre cualquier puerto y protocolo sin URL externa.
- Ojo en C: la asignación debe ser **directa o por un grupo asignado; nested groups no se soportan**. Y Quick Access acepta hasta 500 application segments.

Fuente: <https://learn.microsoft.com/entra/global-secure-access/how-to-configure-quick-access#high-level-steps> y <https://learn.microsoft.com/entra/global-secure-access/how-to-configure-quick-access#assign-users-and-groups>

Q41 Multiple choice

Respuesta: B

Por qué es correcta: Learn: una **Global Secure Access app (per-app access)** es para cuando necesitas **políticas de CA distintas para un subconjunto de recursos o de usuarios**. Quick Access es el bloque principal; per-app es el paso de segmentación en el camino Zero Trust.

Por qué las otras no:

- A. Cambia la política de todo Quick Access y afecta a los file servers. Además, cualquier usuario asignado a Quick Access llegaría al ERP.
- C. Named locations evalúan la IP de origen del usuario, no el destino privado.
- D. Nested groups no se soportan en la asignación, y no resuelve el requisito de política distinta.

Fuente: <https://learn.microsoft.com/entra/global-secure-access/concept-private-access#global-secure-access-app> y <https://learn.microsoft.com/entra/global-secure-access/how-to-configure-quick-access#overview>

Q42 Select two

Respuesta: A y B

Por qué es correcta: El flujo de Learn: filtering policy, **security profile** que la agrupa y **política de CA** que entrega ese security profile a los usuarios. CA es el mecanismo que hace la política **consciente del usuario**: target "All internet resources with Global Secure Access" y sesión "Use Global Secure Access security profile".

Por qué las otras no:

- C. El baseline profile **aplica a todo el tráfico** (incluidas remote networks) sin CA. Bloquearía a todos, no solo a Sales.
- D. El Microsoft profile es para tráfico de Microsoft 365; no filtra categorías de internet.
- E. No hace falta ubicación para este requisito.

Datos que caen: un security profile nuevo tarda de 60 a 90 minutos (viaja en el access token); un bloqueo HTTPS se ve como "Connection Reset"; sin TLS inspection solo aplican reglas por SNI.

Fuente: <https://learn.microsoft.com/entra/global-secure-access/how-to-configure-web-content-filtering#high-level-steps>, <https://learn.microsoft.com/entra/global-secure-access/how-to-configure-web-content-filtering#create-a-security-profile> y <https://learn.microsoft.com/entra/global-secure-access/how-to-configure-web-content-filtering#create-and-link-conditional-access-policy>

Q43 Case study (Multiple choice)

Respuesta: A

Por qué es correcta: El **compliant network check** asegura que el usuario entra por Global Secure Access **de tu tenant**, sin mantener IPs. Si alguien repite un token robado fuera de esa red, Entra lo rechaza, y con apps que soportan CAE el access token también se rechaza casi en tiempo real. Se activa el signaling y aparece la location **All Compliant Network locations**.

Por qué las otras no:

- B. Mantener IPs es justo lo que el requisito prohíbe, y las IPs de salida del servicio no son exclusivas de Fabrikam.
- C. Source IP restoration sirve para logs y políticas por IP (eso resuelve R3), pero vuelve a depender de listas de IPs.
- D. Tenant restrictions controla a qué tenants se entra, no el replay de tokens.

Dato fino: si el cliente no logra conectar, el tráfico del Microsoft profile **se va directo en lugar de bloquearse**; por eso el compliant network check es la red de seguridad. Excluye Microsoft Intune y Microsoft Intune Enrollment para evitar una dependencia circular.

Fuente: <https://learn.microsoft.com/entra/global-secure-access/how-to-compliant-network#enable-global-secure-access-signaling-for-conditional-access> y <https://learn.microsoft.com/entra/global-secure-access/how-to-compliant-network#protect-your-resources-behind-the-compliant-network>

Q44 Case study (Multiple choice)

Respuesta: A

Por qué es correcta: Tenant restrictions v2 decide qué tenants externos se pueden usar desde tus devices y tu red. **Universal tenant restrictions** usa Global Secure Access para etiquetar el tráfico de autenticación con esa política, en cualquier navegador y plataforma, y funciona tanto con el cliente como con remote networks. Viene con el Microsoft traffic profile (P1). Para activarlo se necesitan Global Secure Access Administrator y Security Administrator.

Por qué las otras no:

- B. Outbound controla a **tus propios usuarios** como guests en otros tenants. No impide que alguien use en tu device una cuenta de otro tenant.
- C. Inbound controla a externos que entran a **tus recursos**. Es la dirección contraria.
- D. Source IP restoration es para R3 (logs con la IP real), no para limitar tenants.

Fuente: <https://learn.microsoft.com/entra/global-secure-access/how-to-universal-tenant-restrictions#enable-universal-tenant-restrictions> y <https://learn.microsoft.com/entra/external-id/tenant-restrictions-v2#tenant-restrictions-v2-overview>

6. Plan de la semana y ritual post-examen

Checklist antes de la sesión 3 (Workload identities, 20 a 25% del examen)

- ☐ Leí el mapa y las 12 trampas de M2.
- ☐ Contesté las 44 preguntas de M2 sin ver respuestas y revisé el "por qué las otras no".
- ☐ Anoté las preguntas que fallé para el Kahoot.
- ☐ Hice una vez el practice assessment oficial de Learn, sin estudiar antes.
- ☐ Recibí la guía de M3 y empecé su banco de 40 preguntas.

Si presentas el examen esta semana: llena el debrief el mismo día. Temas sí, preguntas no. Así el cohort acumula señal legítima y nadie arriesga su certificación.

Campo	Qué anotar
Resultado	Pass o no pass y el score por dominio que trae el reporte
Dominios que pesaron	Por sensación: cuál dominó y cuál casi no salió
Escenarios que costaron	Por tema, por ejemplo "AU vs restricted AU", "cross-tenant sync con error de consent"
Labs que salieron	Por tarea, por ejemplo "crear un AU y asignar un rol con scope", nunca pasos exactos
Qué hubiera estudiado más	Libre, en dos líneas

Objetivo de la sesión en vivo, para que sepas qué esperar.

El presenter no tiene que recitar números ni menús. Tiene que entender que casi todas las preguntas de M2 se resuelven con cuatro preguntas: **qué tan fuerte es el método** (MFA, passwordless o phishing-resistant, y dónde se configura cada uno), **qué decide la política** (si nadie dice que no, el token sale; el block, la exclusión de break-glass y el context se diseñan a propósito), **qué riesgo es y cómo se cura** (user risk con password o risk remediation, sign-in risk con MFA, workload identities con otra licencia) y **por dónde pasa el tráfico** (Microsoft, Private o Internet profile, y qué agrega cada uno). Si el presenter puede tomar cualquier pregunta del banco, señalar las dos o tres palabras que la delatan y explicar con sus palabras por qué cada distractor falla, la sesión cumplió. Los números (10 minutos de la TAP, 1000 términos, 99 contexts, 240 políticas, 14 días, 28 horas) se quedan en la guía para consulta.